

CISSP

**SIMPLE AND EFFECTIVE STRATEGIES FOR MASTERING
INFORMATION SYSTEMS SECURITY FROM A-Z**

WALKER SCHMIDT

CISSP

***Simple and Effective Strategies for Mastering
Information Systems Security from A-Z***

Table of Contents

Introduction

Chapter One: Information Security and Its Importance

Importance of Information Security

Better Information Security Boosts Your Confidence

Information Systems Security

The Objective of Information Security

Chapter Two: Security Governance Principles

An Overview of the CIA Triad

Countermeasures

Implementation of Security Governance Principles

Security Function Alignment

Strategic Plan

Tactical Plan

Operational Plan

Organizational Process

Manage Change

Data Classification

Security Roles

Senior Manager

Security Professional

Data Owner

Data Custodian

User And Auditor

Control Frameworks

Due Care

Chapter Three: An Overview of Personnel Security

Job Descriptions

Duties

Responsibilities

On the Job Rotation
Candidate Screening
Agreements
Termination
Vendor Controls
Managing Risks
Risk Identification
Risk Analysis
Risk Assignment
Risk Responses
Mitigation of Risk
Assignment
Acceptance
Rejection
Selection of Countermeasures
Implementation
Control Types
Security Awareness Programs
Training

Chapter Four: Business Continuity Planning

The Scope of the Project and the Level of Planning
Analysis of Business Organization
Team Selection
BCP and Senior Management
Needed Resources
Legal Necessity
Assessment of Business Management
Identification of Priorities
Identification of Risks
Impact Assessment

Prioritization of Resources

Continuity Planning

Development of Strategy

Processes

Approval of Plan

Implementation of Plan

Training

Documentation

The Goals

Risk Assessment and Mitigation

Laws and Regulations

Criminal Laws

Civil Laws

Chapter Five: Security Models and Capabilities

Secure Designs

Subjects and Objects

Open and Closed Systems

Integrity, Availability and Confidentiality

Confinement

Bounds

The Process of Isolation

Controls

Basics of Security Models

Security Models

Trusted Computing Base

Security Perimeter

Reference Monitors

State Machine Model

Chapter Six: Security Vulnerabilities

Memory Security Issues

[Storage Devices](#)

[Storage Media Security](#)

[Hardware](#)

[The Processor](#)

[Input and Output Devices](#)

[The Monitors](#)

[Office Printers](#)

[Computer Accessories](#)

[Internet Modems](#)

[Vulnerabilities in Mobile Systems](#)

[Android Operating System](#)

[iOS Operating System](#)

[How to Secure Mobile Devices](#)

[Encryption](#)

[Remote Wipe](#)

[Lockouts](#)

[Screen Locks](#)

[The GPS System](#)

[Access Control](#)

[Removable Storage](#)

[App Security](#)

[Geotagging](#)

[Embedded System Security and Mitigation Measures](#)

[Security Measures](#)

[Physical Security](#)

[Secure Principles and Facility Design](#)

[Selection of Site](#)

[Visibility of the Building](#)

[Natural Disasters](#)

[The Design](#)

Physical Security Model

Wiring Closets

The Server Rooms

Media Storage Rooms

Chapter Seven: Secure Communications

Voice Communications

Voice Over Internet Protocol (VoIP)

Social Engineering

Multimedia Collaboration

Email Security

Objectives of Email Security

The Issues

Security Boundaries

Mitigation Measures

Denial of Service Attacks

Eavesdropping

Defining Incidents

Response Making

Detection

Response

Mitigation

Reporting

Recovery

Remediation

Lessons

Preventive Measures

Conclusion

References

© Copyright 2020 by Walker Schmidt - All rights reserved.

This document is geared towards providing exact and reliable information in regards to the topic and issue covered. The publication is sold with the idea that the publisher is not required to render accounting, officially permitted, or otherwise, qualified services. If advice is necessary, legal or professional, a practiced individual in the profession should be ordered.

- From a Declaration of Principles which was accepted and approved equally by a Committee of the American Bar Association and a Committee of Publishers and Associations.

In no way is it legal to reproduce, duplicate, or transmit any part of this document in either electronic means or in printed format. Recording of this publication is strictly prohibited and any storage of this document is not allowed unless with written permission from the publisher. All rights reserved.

The information provided herein is stated to be truthful and consistent, in that any liability, in terms of inattention or otherwise, by any usage or abuse of any policies, processes, or directions contained within is the solitary and utter responsibility of the recipient reader. Under no circumstances will any legal responsibility or blame be held against the publisher for any reparation, damages, or monetary loss due to the information herein, either directly or indirectly.

Respective authors own all copyrights not held by the publisher.

The information herein is offered for informational purposes solely, and is universal as so. The presentation of the information is without contract or any type of guarantee assurance.

The trademarks that are used are without any consent, and the publication of the trademark is without permission or backing by the trademark owner. All trademarks and brands within this book are for clarifying purposes only and are the owned by the owners themselves, not affiliated with this document.

Introduction

This book contains proven steps and strategies on how to be well-versed in information technology security. By reading this, you will learn the key ingredients of security. This book will help you learn the key aspects of the Certified Information Systems Security Professional Official Study Guide, Eight Edition. Upon purchasing this book, you will have an easy-to-learn package on the preparation of the exam. Apart from the exam preparation, this book also aims at educating the security managers of different organizations. The book will help general readers and also the students of IT security who are aiming at securing CISSP certification.

Before you start reading, you should have a basic understanding of what IT security is. You should know the basic knowledge of basic mechanisms of IT security such as the infrastructure, different protocols, and security threats. However, even if you don't have a basic understanding, this book covers the basics at the start of each chapter. The CISSP exam is conducted by the International Information Systems Security Certification Consortium. It has different primary mission objectives. The first is the maintenance of the common body of knowledge (CBK) for information security. It is also meant to provide certification for IT security professionals. The book is divided into chapters, each dealing with a different information security aspect that you should consider.

The first chapter of the book is about the importance of information security. The first section of the book sheds light on the importance of information security in a world that is quickly turning from the traditional physical world to all digital. You will know how information security is changing the world and what kind of effects weak information security is having on the world around us. When you start a business, the biggest concern is the trust of your customers, and you cannot win the trust of customers until they know that your organization is perfectly secure and their data is secure too.

For example, if you are running a financial institution, your customers must have confidence in the security of your company to protect their financial interests such as their credit card information. If your organization suffers a data breach, it will start losing business to its competitors, which is bad for the overall reputation of your organization and the health of your investment. Therefore, you should understand how you can secure the organization and

what key aspects you must take into consideration when you are designing a security plan for the facility. The next section of the book deals with the definition of information security, while its sub-section covers the objectives that information security must achieve.

The second chapter of the book focuses on security governance principles. The first section of the book is an overview of the CIA triad. You will learn about the three principles of the CIA triad such as confidentiality of information in the organization, the integrity of the data that is stored and transmitted in and out of the facility, and the availability of the data when the organization needs it. I will also explain in the next section the countermeasures of the CIA triad.

The next section deals with the implementation of security governance principles. Its first subsection deals with the alignment of the security function according to the custom needs of the organization. The second subsection of the chapter covers the devising of a strategic plan that will come into play when the organization needs security. The strategic plan encompasses all aspects of security. It is the lengthiest security plan for your organization. You may include in it all the emerging security concerns like data security, physical security, and virtual security as well. The tactical plan is a short term plan that deals with short term targets for the security of your organization. The last type of security principle is an operational plan that is the shortest plan that can be made in the organization. The operational plan oversees the operations of your organization, ensuring operational security and is the shortest plan in the facility. You have to design, integrate, and operate all the three security plans simultaneously in the organization. All the plans support one another and reinforce one another as well.

The next section of the book deals with organizational processes. Many processes are running in the organization that you have to supervise to ensure that the organization functions well. Its subsection deals with the management of change in the organization. Change is always the toughest to pull off, especially when that change encompasses all sections of your organization. The best thing about change is that it is constant. It will keep occurring and changing the shape of your organization. When an organization goes through change, all the security controls and protocols need to be changed. Everything has to be revised and reconsidered so that there is minimum loss of data and information. Therefore, you will learn how to

manage change while keeping the security of the organization intact.

The second subsection of the organization deals with the classification of data. Data classification should be done so that the staff members should know which data is of more importance than the other. You ought to label the data from top secret to marginally secret so that the staff effectively deals with the data, and the loss of data is minimum. The next section of the book deals with the allocation of security roles to different staff members. There should be a security manager who is well-educated in matters of security who knows how to deal with a crisis. Then there should be a security professional who knows about the technical aspects of information security. Then you have the data owner responsible for managing the data, storing it, and transmitting it inside or outside of the network. There will be one more post of data custodian who will be responsible for managing the security of the data and maintaining its integrity at all costs. The next section of the chapter deals with the control frameworks that manage any crisis circumstance.

The third chapter of the book starts with describing the jobs of different security personnel in an organization. I will explain different job descriptions by explaining what the duties are of different security personnel and what their responsibilities are, and what should be the on-job rotation to maintain the security of a system. There should be a separate document that must explain what each person in the organization does. The on-job rotation is the best way to keep different persons from knowing the secrets of a single place. Once a person completes his tenure, he will be transferred to another position in the same office. This ensures proper auditing in the organization. The new person who takes up the charge on a job turns out to be the by-default auditor of the post and for the previous employee. By this practice, you can maintain transparency in the system.

The next section of the chapter deals with the screening of the candidates. The basic problem is that personnel play a significant role in shaping up the security scenario in an organization. A single person can compromise the security of an organization. Therefore, you should do proper screening when hiring a candidate. He must prove himself reliable for your organization. You must have an agreement signed from them so that the security of the organization is maintained even after you fire that employee from the organization. Your organization must follow a set pattern for terminating employees from the organization so that disgruntled employees may not harm

the organization's security. I will explain in this section how you can manage if you have to fire an employee from your organization out of disciplinary issues or any other ugly reason.

The next section sheds light on the management of risks in the organization. I will explain in detail how you can effectively identify risks in the organization and how you can do the analysis to mitigate the risks. The next section of the chapter explains risk assignment and risk responses. There are certain responses to risks such as the immediate mitigation of risks, the immediate assignment of responsibility for the risks, the acceptance of risks, and the rejection of risks. The last section of the chapter will shed light on the multiple countermeasures to downplay the risks. When you have selected the appropriate countermeasures, the next phase is implementing the countermeasures to minimize the effects of different types of risks. The next section of the chapter will explain different types of security controls. The chapter ends by explaining different types of security awareness programs and multiple types of training.

The fourth chapter of the book focuses on business continuity planning. The first section of the chapter defines the scope of the project and different levels of planning to ensure that the business continues to grow and expand even if the organization faces a security threat. The first subsection explains the analysis of the business organization. The next section is about team selection. You should have a nice and trusted team that ensures that the business doesn't stop even if the organization suffers an attack from a hacker. The senior management has to ensure that the business continues to function amid a crisis. The next section explains how you can run the assessment of business management. You should identify the priorities that must be followed in the wake of a crisis. The identification of different risks is also very important so that you can be able to do a proper impact assessment. This may include assessments like how a certain risk can impact an organization. The next step is to prioritize the resources that you must allocate to minimize the adverse impacts of certain risks.

The next section of the chapter sheds light on continuity planning. The first subsection is about the development of a concrete strategy to ensure continuity planning. In the next step, I will explain the different types of processes that will ensure continuity in the business. The next step is the approval of the plan from senior security management. Then I will explain

how you can implement a certain plan to ensure that the business doesn't stop. I will explain the importance of training in the world of continuity planning. You will also have to document every step of yours. There are certain risks in business continuity planning that you must assess first and then mitigate as well. The chapter ends with the explanation of different criminal and civil laws.

Cybercrimes generally fall under the category of criminal law. The section is crucial because there was a time when people didn't understand the importance to cybercrimes. Many considered cybercrime something that couldn't be regulated by law and courts. However, there are certain legal remedies that you may seek if you are the victim of a cyber-attack.

The fifth chapter of the book is a long one. It spans around the security designs and security models that you must know about if you are taking up the security of an organization in your hands. The first section of the chapter sheds light on the importance of security designs. You will learn about what is meant by subjects and objects in security design. Then you will learn about the nature of open and closed systems in the organization. You will also learn about different ways to ensure the CIA triad that is the integrity of data, availability of data, and confidentiality of data. The subsections of this section will explain the topics of confinement of data and you will also learn about the concepts of bounds, the concepts of the isolation process, and the security controls. The next section of the chapter will help you learn about the basics of different types of security models. You will also learn about the concepts of a trusted computing base in this chapter. The section also contains an explanation of the security parameters and the reference monitors.

The sixth chapter of the book spans around security vulnerabilities. The first section of the chapter deals with the issues of memory security. The two types of memory that will come under discussion are the RAM memory, the secondary memory that is commonly known as the hard disk drives, and solid-state drives. Memory is always vulnerable to security issues and complications. For example, hard disks can be stolen and misused by a malicious person.

The next section in the chapter covers the processor and the input and output devices. You might not have thought about how vulnerable your computer

monitors are to a security attack. In reality, they can be compromised. Office printers are equally vulnerable to security attacks and pose a great security threat to an organization.

Mobile phones used by employees are also a security threat to your organization. The Android operating system is highly vulnerable to security threats as a system. There are loopholes and different backdoor channels from which an intruder can enter the system and steal. This chapter will also cover the technique of securing mobile devices. I will also cover the concept of physical security for an organization, and the security principles and the design of the facility. The selection of the site is also important to ensure physical security.

Chapter seven of the book deals with the concept of securing communications inside the organization. I will explain how communications can be intercepted, stolen, and destroyed. You will find a detailed concept of social engineering that an organization has a threat of. Social engineering can be used to steal important data such as login credentials that give a hacker access to the systems of an organization. Once the social engineer gets access, he can steal the data and inflict significant losses on the organization. I will discuss the concept of VoIP as well. The next concept under discussion is multimedia collaboration—remote collaboration through video conferencing and email systems. At the end of the chapter, I cover the different mitigation measures that you can adopt to ensure the security of the organization. The mitigation measures include the concept of eavesdropping and denial of service attacks.

The final chapter of the book will teach you about devising an incident response system in an organization. The first section of the chapter will define what an incident is and what definition you should add to the security policy of your organization. This chapter also includes certain topics such as detection, remediation, recovery, and lessons you will learn from these incidents.

Chapter One: Information Security and Its Importance

Information security focuses on the security of information that flows in from different sources. Information, in general, remains in danger from unauthorized access, attempts of modification, unauthorized disclosure and usage. Information in an organization can be defined as electronic and physical. Electronic information sits on electronic media such as mobile phones, computers, internet clouds, social media accounts, and the biometric storage systems. Physical information revolves around papers, files, books and any physical piece of document.

The protection of information is gaining importance with the passage of days. You can protect your personal information from getting invaded or stolen by installing multiple firewalls, two-factor authentications, and user permissions. As the use of technology is getting wider, the protection of information is also gaining equal importance. Every industry from a small startup to a technology giant needs technology to fulfill their business need and at the same time to avoid security breaches.

Importance of Information Security

Multiple organizations have recognized how much information security is important for their businesses. Business owners admit that there is no shortage of roadblocks to protect private information from getting leaked in the public space if the information on their systems is privileged. Another concern is that with the rise of tech firms and tech development, there is a steep rise in cyber-attacks.

Better Information Security Boosts Your Confidence

When you have invested in information security, your confidence level improves. If you are running a financial institution and you have to convince prospects to do business with you, you should have confidence that your organization has top-level security to protect the data of your users. You are in a better position to convince your prospects that their financial information will stay secure in all circumstances.

Information Systems Security

Information systems security covers a large number of jobs and careers for

those who are interested in the field and want to make a name in it. The industry is growing at a fast pace and is ready to cover everything from hardware to security breaches. Whether a problem pops up in the hardware system run by the Information Technology department or a breach originates from within an organization or a company, the information security system engulfs everything.

The Objective of Information Security

Information security is about using, accessing, disrupting, inspecting, and modifying the information stored on a system. Information security tends to protect the ability of an organization to function. It ceases operations. It enables the safe operation of the applications that are implemented on the IT systems of an organization. It also safeguards the type of technology that the organization is using.

Implementation of information security systems prevents, detects, or responds to a potential attack on the system. You should keep the staff informed about the security issues through different initiatives and training. Organizations also must enforce information security policies and then review them to meet up their security requirements. The best proactive approach is to evaluate and analyze the threats and vulnerabilities. An organization must enforce information security policies and also keep reviewing them regularly to meet their security requirements.

If you successfully use information security systems, you will be able to ensure confidentiality in your business, proper authentication, integrity of data, and non-repudiation. If you are using different applications in your organization such as web applications and mobile applications, you will be able to ensure the safe operations of applications. This is how you can create a safe environment that will serve as a deterrent for an attack against the infrastructure of the organization.

Chapter Two: Security Governance Principles

Security management principles are usually an integral part of a company's security policy and deployment of its solutions. They tend to define some of the basic parameters that are needed to build a secure environment. These principles also define some objectives and goals that policymakers need to achieve to create a secure solution. CISSP exam students and some real-life security professionals should pay close attention to these elements and understand them thoroughly.

Security spans around achieving the confidentiality of an organization, its integrity, and the level of availability. When combined, these principles are dubbed as the CIA Triad. Security controls are generally evaluated on how they can address core tenets of information security. A security solution must address these tenets in all their entirety. You also can evaluate certain risks and vulnerabilities based on the threats they carry. They are very important in the realm of security. Each principle is meant to depend on the security goals of an organization and security requirements as well to the extent where the security of the organization may be threatened.

An Overview of the CIA Triad

The first principle that must be discussed is the principle of confidentiality. If a security mechanism provides you confidentiality, it means that you are getting the assurance that your resources, data, and objects have been protected from invasion from unauthorized subjects. If the threat persists against the confidentiality of the data, the unauthorized disclosure of information may ultimately take place. If you want to maintain confidentiality on a network, you must protect data from exposure or leakage. No unauthorized person should access the data, use it, or disclose it while the data is in storage, in-process, or in transit. You need unique security controls for resources, data, and objects for the maintenance of confidentiality.

Numerous attacks concentrate on and target the violation of confidentiality. These threats include the capturing of network data and theft of password files. They also span around port scanning, sniffing, social engineering, eavesdropping, and shoulder surfing.

The general violations of confidentiality are not limited to intentional attacks. There are many events of unauthorized disclosure of confidential data. These

are the result of human error, ineptitude, and oversight. Different events that lead to the breach of confidentiality of an organization include the failure in encrypting transmission and failure in the authentication of a remote system before the data is transferred.

Countermeasures

There are some countermeasures that you can take to prevent conviviality attacks. These measures may include robust access control, proper encryption, viable padding of network traffic, classification of data, training programs for office personnel, and working authentication procedures. Confidentiality gets along with integrity as the two depend on each other. In the absence of object integrity, confidentiality should not be maintained. Other conditions, concepts, and aspects of confidentiality are many which I will discuss later.

One aspect is a sensitivity that refers to the level of quality of the information that can inflict significant damage if it gets disclosed. Maintenance of confidentiality of sensitive information will aid in the prevention of damage. The other factor is discretion. It is the art of minimizing damage by keeping disclosure of information at the minimum. Criticality is the level at which information is measured as to how critical it is for the organization. The more critical it is, the more likely it is that the confidentiality of information will have to be maintained. Criticality, at higher levels, is imperative to better operations of an organization.

Concealment is also linked to confidentiality. It is the art of hiding or preventing the flow of information. It can also be dubbed as a distraction, cover, or obfuscation. Another factor is secrecy. It is the act of keeping up a secret or directly preventing the disclosure of information. Privacy is about restricting the flow of information to outsiders. Seclusion spans around the storage of something in a place where no one has expected it to be. You can use it to build powerful access control systems. Related to seclusion is isolation. It is the art of keeping a piece of information in separation from the rest of the data.

The second principle of the CIA Triad is integrity. You must maintain integrity in the organization and the objects need to retain a certain level of integrity. Only authorized subjects should be able to modify the integrity of information. If a certain security mechanism promises to offer integrity, it

will assure you that the objects, data, and resources remain unchanged from the protected state. Alterations must not occur while the object remains in storage or in process. Maintenance of integrity means that the object must not be altered and the programming entities and operating systems that tend to manipulate and manage the object.

You can examine integrity from three different perspectives. The first is the prevention of unauthorized subjects from introducing any kind of modifications. The second is to prevent authorized subjects from introducing any kind of unauthorized modifications like mistakes. The third is the maintenance of the external and internal consistency that objects contain so that the data remains unaltered and a valid reflection of the real world. Integrity is hard to maintain but it must be maintained at any cost. If you want to maintain that properly, you must build proper controls to bar any access to objects, data of your organization, or resources. Activity logging must be employed to ensure that authorized users should gain access. This will help you maintain integrity across transport, controls, storage, and oversight.

You might come across situations in which integrity is severely threatened from multiple directions. The attacks on integrity include coding errors, viruses, sessions of unauthorized access, and system back doors. Integrity violations cannot be limited to intentional attacks just as is the case with confidentiality. They may result from human error and oversight such as some kind of unauthorized alteration of data. Your employees may get involved in the accidental deletion of files, alteration of configurations, use of invalid data, errors in the use of commands, mistakes in scripts and codes, a sneaking virus, or malicious code. Integrity can be demolished by an administrative user or any type of user. They also can occur because of a misconfigured security control.

Multiple countermeasures may ensure integrity against certain threats, and these include access control, intrusion detection systems, and rigorous authentication procedures. Integrity is directly proportional to confidentiality. If you cannot maintain confidentiality, your organization will lose its integrity.

The third principle of the CIA Triad is availability. It means that all authorized subjects must be granted uninterrupted and timely access to

several objects. If a security mechanism tends to offer availability, it will give you a high-grade assurance that the objects, data, and the resources remain accessible only to the subjects who have the proper authorization. The availability feature includes uninterrupted access to the objects. It also includes denial-of-service attacks. It also implies that communication systems, networks, and access control mechanisms are functional. By functionality, I mean that they must give access to authorized users.

If you want availability to stay in the system, you must place sufficient controls to ensure that the system has authorized access. This will allow the system to handle interruptions quickly and efficiently, to prevent any kind of data loss, and to keep up a reliable backup system.

Just like the other two ends of the Triad, availability also suffers from several threats, which include errors in the software of an organization, failure of one or more devices, and environmental factors such as flooding, heat, and power interruption. Other attacks are named as object destruction, denial of service attacks, and interruption in the communication. These attacks are violations.

Just like integrity and confidentiality, the third end gives room to incidental attacks. On top of that is human error that results in the unauthorized alteration of sensitive information. Other factors are known as ineptitude and oversight. Some events that lead to the breaches of availability include mislabeling, deletion of files in an accident, and under allocation of resources.

Among the multiple countermeasures for these sorts of attacks is the building of appropriate delivery systems, effectively using access controls, the monitoring of network traffic, the right use of firewalls to deter DoS attacks, and timely maintenance of backup systems.

Implementation of Security Governance Principles

If you are looking forward to taking the International Information System Security Certification Consortium CISSP exam, you need to understand the basic security governance principles. Security governance is considered the collection of several practices that are related to defining, supporting, and directing your organization's security efforts. The goal of the governance agenda is interrelated. One of the common goals of governance is that the organization must continue to function, grow, and also expand in the future.

Another of the most common goals is to ensure that the business process is maintained while the organization also attains proper resilience and growth. Some governance aspects are usually imposed on different organizations according to the industry guidelines or the requirements of the license. You have to verify and assess security governance for your organization from time to time. As organizations continue to expand and also adapt to cater to the needs of the worldwide markets, the issues related to governance are getting more complex. This becomes problematic when the organization finds itself in a conflicting situation concerning the laws of different countries around the world. The organizations must have the right tools to manage threats and focus on keeping the losses to the minimum.

Security governance can be defined as the process of implanting a certain security solution. It also can be defined as a method of management. It deals with different security levels. It must not be treated as merely an IT issue. Instead, security tends to affect all aspects of a particular organization. It affects the day to day operations of a business. Many people try to confine security governance to the cabins of the information technology (IT) department but that's not possible. It can only be effective if you include all departments of the organization in it.

Security Function Alignment

Security management planning ensures the proper creation and enforcement of a practical security policy. The planning phase strives to bring strategy, objectives, targets, and goals of the organization into perfect alignment. The phase includes the proper implementation of security regarding the restrictions on the budget, the business case, and the scarcity of resources.

Security, quite often, is expensive however it is an integral part of a business operation. In many organizations, resources and money appear to be limited. These limitations compel the managers and owners to extract maximum benefit from small endeavors. One effective method to deal with security management planning is using the top-down method. Senior management is largely responsible for the initiation and definition policies of their organization. When you have developed a comprehensive security policy for your organization, you can move on to the provision of direction for different levels of the hierarchy of the organization. In this kind of scenario, middle management takes the responsibility to map out the policy and create

guidelines, standards, and different procedures. The security professionals and operational managers ought to implement different configurations that are prescribed in the documentation. When the document reaches the end-user, all he or she has to do is to implement the policy.

There also is a bottom-up approach to make security policies. You can start with the IT staff from the bottom. You can assign them the task of making security decisions without receiving any kind of input from the senior management. You can rarely use this approach because the IT industry considers it problematic.

You should design the security tree so that the responsibilities start from the top management and go to the bottom tiers. Some organizations limit security matters to the information technology department only which is a flawed approach and doesn't do any good to the organization. The security plan should include each organizational tier and department to ensure the information doesn't leak out from any side.

Your security plan will be rendered useless if it fails to win the approval of the senior management. Without approval, it is unlikely that the security policy will succeed. The policy development squad must educate the senior management to understand the liabilities, the risks, and the exposures that are left out even after the prescription of security measures. The development of security policy is proof that senior management is taking due care in running the operations of the organization. If a company fails to maintain standard diligence and care, the responsibility falls on the shoulders of managers in the wake of financial losses. The security governance team must develop three major security plans.

Strategic Plan

It is developed for the short term. It contains the definition of the security purpose of an organization. It also helps you to make out how security is going to function in an organization. It attempts to align the security function of an organization with the mission, goals, and objectives of an organization. A strategic plan must be disposed of or replaced or updated after five years. You must also include a risk assessment procedure in the plan.

Tactical Plan

The tactical plan is also known as a midterm plan. It is more detailed than the

strategic plan. It offers more details on the accomplishment of the goals that you have set in the strategic plan. A tactical plan is useful for a year. You can incorporate in it certain schedules to achieve the necessary goals. Some top examples of these kinds of plans are hiring plans, support plans, project plans, system development plans, and acquisition plans.

Operational Plan

It is created for a very short term. It is generally carved out from the structures of strategic and tactical plans. It remains valid for a short time. You must update them according to the tactical plans. You have to include in them budgetary requirements, scheduling of tasks, allotments of resources, and procedures of implementation.

Organizational Process

The second principle is the implementation of organizational processes. Security governance ought to address all aspects of a particular organization. It also includes the processes of divestitures, committees, and acquisitions by the organization. Mergers with other organizations and acquisitions expose an organization to a higher level of risk as there is a change in the staff of the parent organization, the processes, and tasks. Everything from the management to the equipment goes through a change that uncovers loopholes in the system and allows for security breaches of different scales. Your organization may lose small or big amounts of data, fail to achieve the targets of return on investment (RoI) scenarios. You will have to increase security oversight to cut down on the chance of losses as your organization tends to transform.

If you are downsizing or going for a divestiture, your organization will be experiencing a higher risk. Assets must be sanitized to block any level of leakage of data. Storage media must be removed or destroyed before the process because the restoration of data is not always guaranteed. Employees that are laid off ought to be debriefed by the management. This process is known as the exit interview. You can review the non-disclosure agreement that you have signed with the employee at the time of recruiting him or her.

Security governance is being overlooked by experts who analyze and guide the security operations of the staff. Security becomes a complex task if the organization is large and complex.

Manage Change

This is another important aspect of the security governance process which is a branch of the organizational processes. You have to manage well the element of change in the organization. Change, if executed in a secure environment, will show you the existence of loopholes and missing pieces in the structure of the organization. The change should not be rapid or spontaneous. You must plan it ahead and well and you must be systematic in regard to change. It means that you should prepare a plan, test the plan if possible on a pilot project, log everything you are changing, audit the procedures and changes, and monitor the activities of every person who is working to bring about the change.

The main goal of any level of change is to make sure that the change doesn't lead you to make a compromise on the security of the organization. There should be no loose ends for the sake of convenience. The management who is watching over the change process must be authorized and responsible for reversing any change to a secured state. The change control process has certain goals or needs that are as under:

- You need to implement the changes in an orderly and a monitored manner. You must always control them or it will damage the organization.
- There should be a formalized testing process that you must include to verify that the change gives you the desired results.
- You should be able to reverse all the changes that you have introduced to the organization. You may also introduce a rollback plan or a backout plan.
- You also have to inform the users when a certain change is about to happen. It will prevent the loss of productivity in the system.
- The effects that the change has brought about must be analyzed.
- You should work to minimize the negative impact on the functionality and capability of the change.
- The approval board should review and approve the changes.

Data Classification

This also is an organizational process. It is the primary means that protects data for secrecy, confidentiality and sensitivity purposes. If you consider all the data the same during the implementation of a security system, you are following an inefficient method.

If you are not balanced in your approach, you are likely to lose the game. For example, if you are protecting the classified data, you leave the unclassified data at the mercy of breaches. If you are protecting low-level unclassified data, you leave the classified data at the mercy of breaches. Therefore, you have to classify the data in the first stage to know what is and isn't important.

The basic goal of the data classification is the formalization and stratification of the process to secure the data by following certain levels of sensitivity and importance. You can use data classification to store the data, process it, and ultimately transfer it. The system also addresses the subject of removing data and destroying it.

One of the main benefits of data classification is that it demonstrates the commitment of an organization to safeguard certain assets and resources. If you don't classify data, your clients will see through it. This will only drive them away from doing business with you. Not only is it beneficial in terms of attracting more business, but it also is needed to sort out data by identifying the assets that the organization doesn't afford to lose. Data classification also shows how credible your protection mechanisms are. Sometimes, you have to do that as per legal necessities in your state or country. It helps in defining the access levels, the parameters that you will need to declassify the data. Data classification shows you what you can do with the data. You will learn about the timeliness and usefulness of the data. You will learn about the value of the data.

When you are implementing a classification scheme, you should take the following steps:

- First of all, you need to identify the custodian and also define their responsibilities.
- After that, you need to specify how you will evaluate the classification and labeling of the data.
- When you have classified each resource, you have to document it.

- This is time for the selection of the security controls that you will have to apply to the classification levels to provide the requisite protection level.
- The next step is to specify the procedures for the declassification of the resources and procedures to transfer the custody of a certain resource to a specific external entity.

Different levels for the classification of data are top secret, secret, confidential, sensitive, and unclassified.

Security Roles

The next principle is security roles. It is the role that an individual has to play in the implementation of the security scheme. These roles are not prescribed in the job descriptions because they are hardly static or distinct. Getting familiar with these roles will help you establish communication and support structure in the organization.

Senior Manager

You can assign this role to the person who is responsible for the security maintained inside of an organization. It is also assigned to a person who remains concerned about the safety of the assets. The senior manager ought to sign off the activities being carried out in the organization. The security policy is considered ineffective if the senior manager does not sign it. Senior manager holds an important post and he must stay vigilant because he is responsible for whatever happens in the organization, be it the failure or success of the security policy. Therefore, he must endorse the policy with the utmost care.

Security Professional

The security professional's role is generally assigned to an experienced and properly trained person who is well-versed in systems, networks, and security engineering. He carried the responsibility for what goes wrong with the security. The responsibility covers the writing phase of the security policy and the implementation phase as well. You can label the role of a security professional as an IS/IT function role. This role is mostly carried by a team instead of an individual. However, security professionals don't have the power to make decisions. They just implement the ones that are made by the

manager.

Data Owner

You have read about the classification of data. The data owner role goes to the person who carries out the process of classification. He also has the responsibility of protecting the data as well.

Data Custodian

You can assign this role to the person who performs the protection of the CIA Triad. He or she will also perform the duties that the higher management assigns.

User And Auditor

This role is generally assigned to the person who can access a secured system. They have user's access so that they can perform the tasks that are necessary for their job position. Their job is to comprehend and uphold the organization's security policy by following certain operational procedures within the defined security parameters. The auditor has the responsibility to review and verify the implementation of security policy as to whether the standards are followed during the implementation phase or not. The Auditor ought to ensure compliance. He also produces reports that the senior manager reviews afterward.

Control Frameworks

Another principle that you must memorize is control frameworks. Security policy is not just a draft that you can write in a couple of days. A considerable amount of planning goes into the making of solid policy. The most important part of security planning is considering the control structure and framework of security solution that suits the organization. There are different options to consider.

Due Care

Planning for security is important. One reason is the need for due care. Due care means that you should take care of protecting your organization's interests through your security policy. Coupled with it is due diligence, which is about practicing different activities that will maintain the efforts you make to keep up due care.

Chapter Three: An Overview of Personnel Security

Humans are considered the weakest link in a security loop. No matter how comprehensive and logical controls you deploy in your organization, it is likely someone in the organization avoids them or break the rules. He or she may disable the system or subvert it. Therefore, you must take into account the humanity of users when you are designing or deploying a security solution for the environment. If you want to have a clear understanding of security governance principles, you ought to spot the weakest link in the security chain, the personnel in your organization.

The first step to tackle personnel security and the risks that are related to them is that you need to understand the problems, issues, and compromises at different stages of security. This happens because humans are usually involved in the development, deployment, and ongoing administration of solutions. You need to evaluate the personnel in your organization system.

The hiring of new staff involves several steps such as the creation of a particular job description, the setting up of job classification, the screening of candidates, the hiring and training of the personnel to make them a fit for a particular job. If you don't have a job description, you cannot agree upon what are the personality traits that you want in the personnel that you have hired. Crafting job descriptions is considered the first step in mapping out the security needs of the personnel. You must hire personnel according to the needs of your organization. The job description must address possible security issues that are bound to pop up from time to time. You ought to consider whether the hired individual can handle the organization's sensitive material or whether he or she should have access to classified documents.

Job Descriptions

The first step in formulating an organization personnel security is drafting an appropriate job description. Here are some of the elements that you must take into consideration while preparing the draft.

Duties

The first step you should take care of is the separation of duties. It is the security concept which demands that you divide the sensitive and critical tasks among individual administrators. This is how you successfully prevent the access of a single individual to sensitive information. This limits that

person's ability to undermine the security mechanisms of your organization. You can divide the sensitive duties from the lower order to the upper order. By separating the duties among the individuals, you can give your organization cover against collusion, which means you save your organization from fraud, espionage, and theft.

Responsibilities

You should define job responsibilities in the job description. Responsibility is the task that an employee of your organization has to perform. Based on responsibilities, employees may demand access to different types of information, objects, and services. When on a secured network, users ought to be granted access only to the elements that they require to perform a specific task. You must sort it out according to the principle of privilege. Less access should be given to the least privileged employees while sophisticated access should be given to the most privileged employees.

On the Job Rotation

Rotating employees on the job in between multiple positions is how an organization can improve its security. It serves two functions. The first type is to provide a particular kind of redundancy of knowledge. When multiple employees can perform different tasks that are native to different positions, the organization can avoid a severe kind of downtime or a fall in productivity in the wake of any unexpected event.

In addition to that, shuffling personnel in the organization will cut down the risk of on-job fraud, theft, information misuse, and modification of data. If a person stays longer at a certain job position, they are likely to get additional tasks and expand their access and privileges. Ultimately, they may get involved in abusing their positions and privileges to get personal benefits. Another benefit of on-job shuffling is that when another person takes up the role of his peer, he gets in a position to audit what the previous employee had been doing.

When multiple people work in collaboration to commit a crime, the process is dubbed as collusion. If you must award access privileges to your employees, you need to keep a strict check on their usage. You should monitor the activities of user managers, administrators, and backup operators.

Once you have drafted a job description, you ought to keep it throughout the

life of your organization. Only a job description can give you a detailed difference between what a person should do and what a person can do.

Candidate Screening

The next step is to make sure you are screening the candidates wisely. Your employment candidate screening must be based on the classification and sensitivity of the job. The sensitivity of a job position depends on how harmful the employee can be for the organization if he starts abusing his position and privileges. An accident or an incidental violation may cause a level of harm.

Screening of the employees, through checks on his background, checks on his reference, and verification of his education are integral parts of in proving that the candidate is properly qualified and trustworthy for a specific position. The background checks on the candidate mean that you have acquired the educational history of the employee like where he studied and what were his grades? You must check if he is speaking the truth about this educational qualification. This may include interviewing neighbors, colleagues, and friends. You may move on to giving a thorough check on the government records about that person as to whether that person was involved in any kind of arrest or other illegal activities. You can verify identities through a birth certificate, fingerprints, and driver's license. If you want to do additional checks for more confirmations, you can give a comprehensive check on that person's social networking accounts. You can see what he is posting about. If you find any inappropriate content on his social media feeds, he will not be an attractive candidate for your organization. It is the best option to skip them on to the other candidates. His online identity can tell you whether he speaks the truth about his identity in the online spaces. You also can tell whether his posts make sense and what is attitude. One of the most important behavioral traits to look out in the social media feeds of the candidate is to see whether he is being involved in any kind of propaganda like religious or political propaganda or not. If you get even a slight hint of that, he is not a good option for you.

Agreements

When you hire a new employee, you should get him to sign an employee agreement. The document may outline the restrictions and rules of the organization, the acceptable usage, and the general policy to maintain the

security of the organization. They may contain clauses on violations and their consequences as well. You can use the employment agreement to verify whether the employment candidate has comprehended the documentation for the job position.

In addition to these agreements, you also can get them signed a security document. One of the most common documents is a nondisclosure agreement (NDA), which is used to safeguard the confidential information inside the organization and keep it from being disclosed by the former employee. When the candidate has signed the NDA, they agree that they will not disclose any kind of information even after leaving the organization. If they violate the NDA, they will be liable for strict penalties.

Throughout the employment time of personnel, the managers must audit the job descriptions, the privileges, and the responsibilities of each employee. As the organization evolves, the responsibilities may tend to drift from time to time. This may result in violations of security. If you regularly review the limits of a job description, you minimize the level of these violations. The key part of the review process is to enforce mandatory vacations.

Termination

This is one of the most important when it comes to the security of the organization. A termination is an unexpected event that the organization must plan for ahead of time. This demands the presence of a powerful bond between the security department of an organization and the human resource department. A well-structured termination process is key to keeping a safe environment in the organization so that a disgruntled employee may not work against the organization.

If you have read about cybersecurity and ethical hacking, you might know how social engineering is executed. A social engineer, who is a hacker, approaches a disgruntled employee and makes him speak up the most secret information about the organization. The information may be about the passwords, encryption codes, and security cards. This can be lethal for the organization if you don't give it due importance. A terminated employee may exhibit destructive rage and destroy the organization.

Therefore, you need to design and then implement a working procedure to handle terminations. First of all, there should be a witness to the termination

which can be a higher-level manager or a security guard. Once you lay them off, they ought to be escorted out of the organization. Also, they must not be allowed to return to the premises of the organization. The best time for the termination is the closing of their work shifts.

If the situation is not that much worse between the organization and the employee, you should perform an exit interview. Usually, this depends on the mental state of the terminated employee. You can conduct right after termination or a little bit after that. Other things that you ought to consider upon the termination of the employees are:

- The terminated employee must return any organization equipment he possesses.
- You should disable their user account.
- Pay him the last salary. Pay the unused vacation time as well.
- Circulate his name and picture among the security personnel with the directions that the employee should not be let into the premises.

Vendor Controls

Contractors and vendors are usually used to defining certain levels of performance and consequences for persons and organizations that are usually external to your organization. These documents are known as service-level agreements (SLA). Using the SLAs is considered a popular way to ensure that organizations offer services to external and internal customers. SLAs are generally important when you are using a third-party provider and include cloud services as well.

Managing Risks

Security aims at the prevention of loss of the disclosure of data while you are sustaining authorized access. The possibility that something may happen that can damage, disclose, and destroy your organization's data or resources can be labeled as a risk.

Risk management is the element of not only building but sustaining a secure environment. It is a detailed process to identify a range of factors that will leak important data. It evaluates the factors and calculates the cost for

countermeasures. It also implements cost-effective solutions to mitigate the risk. The risk management process spans around the development and implementation of multiple strategies to ensure security. The ultimate goal is to cut down the risks.

In the first stage, you have to bring down the security risks to the minimum. The steps to achieving may vary for each organization according to their infrastructure and value of assets. Risks vary in nature. All risks that pertain to the IT department cannot be linked to computers. If you fail to determine and evaluate the costs of risks, you cannot timely respond to them. In the wake of this kind of circumstance, your organization will be left vulnerable to attacks and security breaches. Firewalls can only protect against technical and logical attacks. If you want to protect your organization against physical attacks, you must erect certain physical protections.

The process that can help you manage risks is known as risk analysis. This includes examining the environment for certain risks, the evaluation of threat events, and the cost of damage it is likely to cause if it must occur. It also includes the creation of costs and assessment of countermeasures that pertain to each kind of risk.

An asset is something in the environment that needs to be protected, such as a computer file, a process, a database, a software or hardware devices. It can be personnel and even a piece of furniture.

Risk Identification

One of the key parts of risk management is identifying threats and potential weaknesses in the system. The first step is to create an exhaustive list of the possible threats concerning identifying the assets. This element list must include several threat agents. You must define the possible origin of each threat. Keep in mind that you must take into account the physical threats to the IT infrastructure as well. Take the following into consideration when you are drafting a list of the possible threats.

- One of the top threats is from viruses.
- Authorized users may be involved in criminal activities.
- Existence of malicious hackers
- Natural disasters, such as volcanoes, earthquakes, tornadoes, and

tsunamis.

- Physical damage like projectiles and crushing
- Misuse of services and data
- Government and political issue
- Extreme temperatures
- Data loss

Risk Analysis

The next step is to analyze the risks. Risk management is an exercise for upper management as it is their responsibility to support risk assessment and analysis. You must understand all the results, assessments, decisions, and outcomes and get them approved by the upper management.

All IT systems are at risk; therefore, you cannot do away with one hundred percent of the risks in the system. Instead, the upper management ought to decide which risks are more acceptable to you and which are not. The determination of the risk factors requires complex risk assessments. Once you have analyzed the threats, you can evaluate each threat and the related risk.

You can do this by quantitative risk analysis. You can evaluate the risks in terms of dollars. You can prepare budget reports which any person with the knowledge of spreadsheets may understand. This is how you can calculate the costs and also evaluate how much you will have to spend on mitigating the risks. Here are the six major steps that are involved in the quantitative risk analysis procedure.

Risk Assignment

The results of risk analysis can be different such as the following:

- You may end up having a complete valuation of the assets of the organization.
- You may have an exhaustive list of the risks and threats, the extent of the loss, and the ratio of occurrence.
- You may have a list of safeguards and a list of countermeasures that identify the effectiveness.

- You will also learn about the cost and benefit of taking up different safeguards.

You need all this information to form an educated and intelligent opinion and make decisions about implementing different safeguards and options of certain security policies. Once you have finished the risk analysis of your organization, as a manager you need to address the risks.

Risk Responses

When you know what type of risks you are facing in the organization, you can map out the possible responses to those risks. Take a look at all the possible responses that you make take.

Mitigation of Risk

Mitigation of risk involves the implementation of different safeguards that can help eliminate possible threats. The best technique is to pick the most beneficial and effective countermeasure. However, it doesn't fall into the category of risk mitigation. The selection of countermeasures is a post-risk analysis activity. One of the most recommended and most effective countermeasures is avoiding the risk in the first place. You can root out the cause of the risk and eliminate it.

Assignment

You can assign the risk to another organization by outsourcing and buying insurance.

Acceptance

The third is accepting the risk. That's how the management can evaluate the cost-benefit analysis of all the possible safeguards. They also can determine that the cost of the countermeasure may outweigh all the possible costs of loss. It means that management has accepted the consequences and the loss if the risk has been realized. The acceptance of risk demands a neatly written statement that shows why the management missed out on implementing the required safeguard. It will tell who was responsible for the bad decision. Risk tolerance is the capacity of an organization to take on maximum risks. You also can name its risk appetite.

Rejection

The last factor is known as the rejection of risks. The final response is to reject the risk altogether. If you deny that a risk exists and hope that it will never materialize, this is not a valid supposition.

Once you have implemented all the countermeasures, the remaining risk is known as residual risk. It comprises of threats to particular assets against which the upper management opts not to place a safeguard. Residual risk is the one that the management has chosen to accept. The total risk is the quantity of risk that an organization might face if it implements no safeguards at all. It contains the total number of threats, vulnerabilities, and value of the assets.

The difference between residual risk and total risk is known as control gaps. It is the amount of risk that is cut down after the implementation of certain safeguards.

Selection of Countermeasures

Next on the line is the selection of countermeasures. The selection of countermeasures relies on how you conduct the cost-benefit analysis and what results you get. However, you ought to consider several factors when you need to assess the pertinence of security control:

The first factor is the cost factor. You should take care that the countermeasure should not be more than the actual value of a particular asset. The cost of that countermeasure should not exceed the benefits of countermeasures. The result of the countermeasure should show that the cost of the attack was less than its benefits. The countermeasure must be ready to be disclosed before the public. It should be able to withstand any level of exposure and scrutiny.

You must be able to test the benefits that a countermeasure may have for your system. The countermeasure should provide consistent protection on all the protocols. There should be a few dependencies to decrease the failure of cascades. You should make sure that the countermeasure has not been tampered with.

Implementation

The next step is the implementation of security measures and different types of controls. All of them should be implemented physically or logically. The

three categories of the security mechanisms must be implemented manner in the form of layers to ensure a defense-in-depth format.

Technical access spans around the software and hardware mechanisms that are used to manage access and also provide certain protections for the systems and resources. As implied by the name, it demands the use of technology. Its examples include certain authentication methods such as smartcards, usernames, and biometrics.

Administrative controls pertain to certain procedures that are defined by the security policy of the organization and different other regulations and requirements. You also can name them as management controls. It's different examples include classification of data, hiring practices, labeling, background checks, security awareness, vacation history, and work supervision.

Physical control items can be touched. They include certain mechanisms that you can deploy to prevent and detect direct contact with several systems inside the facility. They include installing fences in the organization, the lights, the badges that security personnel wear, the dogs that are trained for security, the cameras that are used for surveillance purposes, the mantraps, and different types of alarms.

Control Types

Controls are of different types. Powerful controls can help you ensure foolproof security of your organization. Controls tend to defuse a wide range of IT security risks. Whenever you think about a security problem, the first thing that comes to your mind is that you must prevent it. However, whenever an unwanted scenario materializes, the security situation slips out of control. Let's take a look at different types of controls.

The first is a deterrent. You can deploy this access control to discourage the violation of several security policies. It is similar to preventive control which I will discuss in the next paragraph. However, deterrent control usually depends on the individuals who decide against taking an undesirable action. On the contrary, preventive control blocks action. A few examples of preventive controls include security-awareness training, mantraps, fences, and hiring of security guards.

Next comes preventive control. You can deploy it to block an unwanted action before it occurs. Different examples of preventive control include

mantraps, fences, locks, alarm systems, conduction penetration testing on the IT infrastructure to test cybersecurity, executing auditing of the systems, encryptions, installing lights and cameras, introducing smartcards in the organization, drafting and implanting practical security policies, and conducting security awareness training. It also includes firewalls to protect the systems.

The next line is detective control. You can deploy this type of control to detect or discover any form of unwanted activity. These control can only work after the activity has occurred. Common examples of detective controls are audit trails, on-job rotation, supervision, security guards, IDSs, security cameras to review video footage of the suspected areas.

Security Awareness Programs

The key to building a secure environment in an organization is to ensure properly managed security awareness programs. The modification in behavior involves a certain level of learning that a user acquires. If you want to develop a particular level of security education, awareness, and training, you should identify all aspects of the transference of knowledge. You must also identify all the programs of exposure, presentation, and implantation.

One of the prerequisites of security education is dubbed as awareness. The major goal of building awareness is to recognize security as something that should remain at the forefront. You must make security a recognized entity. When you have created sufficient awareness about security among the people, you will succeed in establishing a solid foundation for security understanding among the employees and management of the organization. Security awareness campaigns are not exclusive to classroom exercises. You also can introduce them through your work environment. You can use many tools to spread awareness such as newsletter articles, posters, announcements, office supplies, notices, and specialized instructor-led courses. You can hire an expert who will train your staff regarding the key aspects of security. You must make all personnel fully aware of the responsibilities regarding the security of the organization. You should ensure that they must receive adequate training as per the liabilities of their job. The awareness program ought to be linked to the security policy, the recovery procedures in the wake of disasters, and handling certain incidents that pop up during the normal operations of the organization.

The staff must be aware of different security issues like avoiding fraud, waste and different sorts of unauthorized activities. There must not be any kind of discrimination among the members of staff regarding security awareness programs and pieces of training. Everyone from the senior management to the low-level staff must receive a similar awareness level. In fact, the awareness program in the organization ought to be paired up with the security policy so that it complements the policy. If you desire to make your security awareness program effective, you must keep it fresh, updated, and creative. In addition, you should calculate how your awareness program will impact the corporate culture in your organization and the security of each individual of your organization. The employees of the organization must see the effort behind the implementation of security policies. If they see them, only then will they feel obligated to abide by them.

Training

Coupled with the concept of security awareness is training. Training can be defined as teaching the employees on how to perform the work tasks and how they can comply with the organization's security policy. An organization funds and organizes training. It is generally targeted at different groups of employees that perform similar job functions. When you hire a new employee, he or she requires immediate training on security to comply with the security policy. The training can be on different topics. For example, you can add to the training courses the method to use the IT infrastructure of the organization. You can train them on how to store the data so that it stays secure. You can train them on handling the resources that you think are highly classified. It is the standard procedure with different organizations to give their newly hired employees training of some level. They only grant their access to work after they are well versed in the working of the organization. If you want your employees to start working immediately after hiring, you may offer your employees limited access to the organization's network until they have completed their training. If you want to keep your employees updated with the latest changes in the security policy as per the latest challenges, you have to look at security policy as an ongoing activity. Training should be sustained.

As times change and people have to go through several security challenges, you should keep revising and improving the security policy over time. However, as the course and methods of the training change, you should

introduce the testing process as well to ensure that the employees are retaining the knowledge that you are imparting on them. This demands that you must collect and evaluate how the employees are taking the security training sessions. Once you have completed a training session, you should monitor the employees to check whether they are consistent in the job or have improved. A good sign of successful on-job training is that you should witness a visible fall in the downtime in the organization, a decrease in security incidents or human errors. The process is known as the evaluation of the effectiveness of the program.

The best way to provide training and awareness is to conduct them in the house. This means that you should hire professional trainers to develop and use teaching tools inside of the organization. However, you can opt for an advanced level of the distribution of knowledge from a third-party source.

Chapter Four: Business Continuity Planning

Business continuity planning (BCP) suggests that you make a thorough assessment of the risks that your organizational processes face. It also involves creating security policies, plans, and procedures to cut down the impacts that those risks might have on your organization. Business continuity planning is generally used to attain the maintenance of the continuous operations of a certain business if an emergency situation arises out of the blue. The basic objective of BCP is the implantation of different policies, processes, and procedures.

BCP tends to maintain the smooth flow of business operations in the wake of the existence of limited infrastructure. BCP focuses on providing a calm, quick, and efficient response when an emergency pops up. It also enhances the ability of a company to recover from a disruptive event swiftly and efficiently. A BCP consists of four steps such as the following:

- The project scope of an organization and the level of planning to accomplish it.
- It spans around the assessment of business impact.
- It focuses on the level and pace of the continuity of planning
- It revolves around the approval process and the implementation process.

The Scope of the Project and the Level of Planning

As is the case with a business process, a robust BCP demands the use of a well-crafted methodology. This demands the following:

- A structured analysis of how the business organization works in the wake of a crisis.
- It involves creating a BCP team that has approval from the top management.
- It involves assessing numerous resources that are available with the organization and that can help manage the business continuity.
- It involves analyzing the legal landscape that regulates how an organization responds to a crisis.

Analysis of Business Organization

One of the responsibilities of the people responsible for BCP is to perform the analysis of the organization of business to identify different departments that tend to have a stake in the BCP process. Here is a list of the areas that you must consider.

- You must identify the operational departments that have to perform the core services for the clients.
- You must identify different critical support services like information technology and the facilities for maintaining the systems that ought to support many organizational departments.
- It revolves around corporate security teams that are generally responsible for the physical security of the organization because they usually act as first-responders when an incident occurs. They also are responsible for the physical safeguard of primary facilities.

The process of identification tends to be critical for two reasons. Firstly, it offers the base for the identification of the BCP team. Secondly, it prepares the ground for the remainder of the BCP process. Usually, the business organization analysis is performed by several individuals that look over the general BCP process.

Team Selection

In some organizations, the security departments are provided with the sole responsibility to sustain BCP. There is usually no input from different operational and support departments. Those departments may not know the existence of a plan until a disaster strikes and this is generally a flaw. An isolated department that has the sole responsibility to perform BCP has two ways to define a disaster. To prevent any kind of crisis, the management of the organization should take care while choosing the team. There are some key designations that the team must comprise of.

- The representatives of different departments of your organization are responsible for performing the core services performed by your business.

- It must contain the representatives of support departments that are identified by the analysis of the organization.
- It must contain the representatives of the information technology that have technical expertise in the areas which the BCP cover.
- It must contain the security representatives who possess knowledge of the BCP process.
- The team should also have representatives from the legal department familiar with the regulatory, legal, and contractual responsibilities.
- The team should also have representatives from the senior management.

You should pay special attention to the construction of the team. The team members should contain representatives of multiple opinions and also fiery personalities as well. Your major objective should be to create a group that must be full of diversity but tends to operate in a kind of harmony. You must take some time to ponder, upon creating BCP membership, what will be suitable for the financial, technical, and political environment of the organization.

Each individual in the list has a unique perspective for smoothing the flow of the BCP process. The representatives may also contain certain individual biases. The representatives of each department will consider the department the most critical to the viability of the organization. At first, these biases appear to be divisive however the leaders of each department must harness it in a highly productive manner. If you can use these biases effectively, they will help in achieving and maintaining a healthy balance for the final plan. If the leadership is not up to the mark, the same biases many turn out to be highly destructive. It will eventually put the entire BCP effort in jeopardy and will eventually harm the organization.

BCP and Senior Management

The role of the senior management in executing and ensuring the entire BCP process tends to vary from one organization to another. It also depends on what type of internal culture a business organization has. The smoothness of BCP also depends on how much interest the senior management has to

conclude the process. Moreover, it depends on the legal environment where the business operates. The most important roles that are played by the organization are ensuring the provision of the staff and ensuring the provision of appropriate financial resources. It also spans around the arbitrary disputes that decide upon how critical each service is.

When a senior manager takes up the responsibility of working and implementing the proper business continuity plan, they should play an active role. This ensures that a similar attitude will be reflected in the staff of the organization.

Needed Resources

When the BCP team validates a business organization analysis, it must turn to the assessment of different resources that are required by the BCP effort. There are three general resource requirements that you must adhere to.

The first is the development of BCP. The team will be needing some resources to perform four elements of the BCP process such as the scope of the project, assessment of how the business makes an impact, planning to ensure continuity, and the approval phase. A big chunk of this resource goes to the team members who develop the BCP plan.

The next is training, testing, and maintenance. The organization has to go through these three phases to ensure a smooth implementation of BCP. The management must provide different commitments on software and hardware.

The third needed resource is in the situation when the disaster actually hits upon the organizational structure. When the disaster finally strikes and the organization's BCP team finds it essential to implement the continuity plan, as a manager you will need several resources.

If you want to run an effective BCP, your plan demands a great number of resources right from the purchase of computing facilities to the stationary that you will be using the offices to make the first sketches of the plan. Personnel is at the top in terms of consumption of the resources by BCP. Some security officials overlook the element of labor.

Legal Necessity

A BCP plan also is a legal necessity. Several industries are usually bound by the federal and local laws that bind them to ensure effective implantation of

different degrees of BCP. Many countries require brokerages and banks to follow strict government requirements and security regulations. If the law of your country does not bind you, your client may bind you into performing certain obligations regarding your contractual responsibilities. This may include abiding by the law.

Robust development of the BCP plan tends to support your organization to secure new clients and get repeat business from the existing clients. If you can show the customers some robust procedures that you have for the organization, it will place you in a better position to compete with the rest of the organizations. Customers like to do business with organizations that are resilient and secure and have proper systems in place to deal with any kind of untoward situation. So, if you are looking forward to working toward the satisfaction of the customers and to win customer loyalty, you must address all these concerns by adding a legal counsel to the BCP process. A legal counsel is well-versed in the regulations, the legal requirements, and the contractual obligations you have toward your customers. This is how you can ensure that the shareholders, employees, customers, and suppliers equally benefit from the planning and the processes of the organization.

The laws that a legal counsel must rehearse well are different types of business practices, computing systems, and different changes in the organization.

Assessment of Business Management

Once the BCP team finishes the four stages that are involved in the preparation of a BCP, the time is right to dive fleshing out a business impact assessment (BIA). It tends to identify different resources that must be critical to the viability of the organization and also to the threats to its resources. It also offers assessments on how much the likelihood is of the occurrence of a threat. It will also assess the impact that these kinds of occurrences have on your business. BIA results offer the quantitative measures that can help you calculate and allocate the number of resources that you must give allocate to regional, local, and global risk situations that your organization face during its operations.

Quantitative decision-making is about the use of formulas and numbers to reach a certain decision. The data type expresses different options in the form of dollar value to your organization. On the other hand, quantitative decision-

making considers different factors like the stability of the workforce, the emotions, several numerical factors, and different types of emotions. The BIA process approaches a problem from a qualitative and quantitative point of view.

Identification of Priorities

The first task that the BIA team faces is the identification of the priorities of your business. Depending on your business, there will be different activities imperative to the day-to-day operations in the wake of a disaster. The identification task involves the creation of a lengthy list of certain business processes. It will also rank them per the importance of the order. This task may appear to be daunting at the start but it is not that hard as it appears to be.

One of the great ways to divide the workload in the process is to assign the participants the responsibility for creating a list that caters to the functions of each department. The process facilitates the identification of certain business opportunities from the qualitative point of view.

Identification of Risks

The next step in the process is identifying risks to the organization. Some of the elements of the list are easier to guess. There generally are two kinds of risk; one is man-made and the other is natural. The following section contains the risks that are natural and non-natural.

Your organization may experience tornadoes, storms, blizzards, and fierce storms. Non-natural or man-made threats span around theft, vandalism, failures of transportation, ignition of fires, and different categories of explosions, the collapse of a building, and prolonged power outages.

The lists may contain more elements. You can add them as you deem fit. For example, the particular area in which your organization is operating might experience urban flooding or cyclones. This process is generally qualitative in nature. While preparing the list of risks, the team should not be concerned about the exact estimate of the damage that a particular risk may bring for you.

Impact Assessment

You might have surmised on the basis of its name. Impact assessment is the

key portion of a business impact assessment. In this particular phase, you ought to analyze different types of data that are collected amidst the identification of risks and the likelihood of the assessment. It also attempts to determine what kind of impact a risk might leave on your business if it materializes.

Prioritization of Resources

The last step in the BIA is prioritizing the resources to different types of risks that you must identify and assess in the preceding tasks. All you need to do is to create a list of all the possible risks you must analyze through the BIA process and then sort them in the descending order as per the ALE computed during the phase of impact assessment. This leaves you with a prioritized list of different types of risks you ought to address.

Continuity Planning

The maiden two phases of the BCP process that spans around the scope of the project and the business impact assessment focuses on how BCP works. The next stage of the BCP development is known as continuity planning and it focuses on the development and implementation of a continuity strategy to slash the impact that certain assets tend to have on the protected assets.

Continuity planning is the next phase of BCP. It focuses on the development and implementation of a particular continuity strategy to reduce the impact of risks on the assets. You will have to develop a unique strategy, ensure certain processes and provisions, approval of risk management plans, implementation of plans, designing security awareness programs and security training.

Development of Strategy

The development of strategy brings together continuity planning and business impact assessment. The BCP team must analyze and study the prioritized list of concerns raised by the qualitative and quantitative prioritization exercises. If you want to address all the possible contingencies, you will need to require the implementation of certain processes that will ensure that there is zero downtime in the wake of each risk.

BCP team must look back at the MTD estimates that were formed in the early phases of assessment. It also determines the risks that are deemed

Processes

The process phase is considered the spirit of a continuity plan. BCP team has the responsibility to design particular procedures that will decrease the risks that experts consider unacceptable in the development of a strategy. You ought to protect three general types of assets through the processes and provisions of BCP such as buildings, people, and infrastructure.

The first on the line is people. The foremost thing is that you ought to ensure that the people in your organization are considered safe in the wake of an emergency. The moment you achieve the goal, you need to make provisions to allow the employees to execute operational and BCP tasks normally. As a senior manager in an organization, you must not let yourself forget the fact that people always turn out to be your precious asset. You must keep the safety of the people at the forefront. You ought to make sure that the continuity plan should make sufficient provisions to ensure the security of the customers of your organizations, the suppliers, and the employees.

As a manager, you must provide the people with the resources to complete the assigned tasks. However, at the same time, if certain circumstances dictate that people should remain inside the workplace for prolonged periods, the organization must create the necessary arrangements for the food and shelter of the staff. A continuity plan that must include these sorts of provisions ought to include necessary instructions for the BCP team if a disaster occurs.

A lot of businesses demand specialized facilities to carry out a bunch of critical operations. They may contain manufacturing plants, warehouses, repair, and depots, etc. When your staff or you perform BIA, you will be able to identify certain facilities that will one day play a critical role in establishing the continued viability of the organization.

Almost all businesses in the world depend on different types of infrastructures to keep up critical processes online. The most critical part of each infrastructure is the computer networks and the communication system. The computer systems of IT infrastructure are responsible for processing different types of orders, managing the entire chain of supply, and handing interaction by the customers. BCP addresses how the systems must be protected against certain risks identified during the development phase of the strategy. As is the case with facilities and buildings, there are two methods of

providing this protection.

Approval of Plan

Once the BCP team finishes the design phase of the BCP document, it is high time to achieve top-level management and endorsement of your plan. You must attempt to develop a plan that is endorsed by a top executive in the business such as a president, chief executive officer, chairman, and business leader. The specific move shows the importance of the plan to the entire organization. It also showcases the commitment of a manager or an executive to sustain the continuity of a business.

Implementation of Plan

Once you have acquired the approval, you can dive in and initiate the implementation of the plan. After you have developed the resources, the BCP team must supervise the behavior of the maintenance program to make sure that this plan should remain responsive to the evolution of the business needs.

Training

It is the most vital element of BCP implementation. All the personnel involved in the security plan must receive some kind of training on the plan and responsibilities of the individuals. Each member of the organization must receive a plan to give him or her the confidence that different leaders of the business have taken into account possible risks that may surge along the way.

People who have direct BCP responsibilities must be trained on the specific tasks to make sure that they must efficiently fulfill them whenever some kind of disaster strikes. You must train one backup person for each BCP task to ensure that the work process doesn't stop in the wake of an emergency injury.

Documentation

Documentation of BCP is considered a critical step in the continuity planning of a business. Jotting down the BCP methodology on a piece of paper tends to offer key benefits such as the following:

- It gives a historical record of the BCP process that ought to be useful to the future personnel.
- It also ensures that different BCP personnel must have a written

continuity document to be used as a reference.

- It compels the team members to ink their thoughts onto a piece of paper which is a process that facilitates the identification of different flaws in your plan.

The Goals

The plan must describe the goals of the planning more clearly as it is set forth by the BCP team and the senior management. The goals ought to be decided before the maiden meeting of the BCP team. It will be most likely to stay unchanged during the life of BCP. One of the common goals of BCP is to ensure that the business runs smoothly and without any sort of interruptions in the wake of an emergency situation. You also can add to the continuity planning document other different other goals.

- You must include in the continuity planning document a statement of importance that reflects a certain level of criticality of BCP to the viability of the organization.
- The second most important statement is the statement of priorities that must flow from the phase of identity priorities of assessing the impact of a business. This also involves the listing of the functions that are considered crucial to certain business operations in a prioritized order. While writing down and sorting out these kinds of priorities, you also need to include a certain statement developed as a part of the BCP process. It reflects how important the different functions are for the smooth flow of the business operations if an emergency pops up.
- You must be clear about the responsibility of your organization. Therefore, you must develop a statement of organizational responsibility. It restates the commitment of the organization to sustain continuity planning and inform the vendors and employees that they have to individually do things they have in their power to assist with the BCP process.
- The statement of timing tends to express how critical the implantation of BCP is. It also outlines the implementation of the timetable usually decided upon by the BCP team and greed by upper management.

Risk Assessment and Mitigation

The risk assessment portion of the BCP documentation tends to recap the process of decision-making usually executed during the assessment of the impact of your business. It must include a certain discussion on different types of risks that are usually considered during BIA.

The risk assessment section in the BCP documentation usually contains the general outcome of the strategy development portion of the process. It must cover each type of risk that is identified in the analysis section of the security document. It will also outline the following processes.

- For the risks considered acceptable, it must delineate the reasons as to why the risk had been considered acceptable and potential events.
- For the risks considered unacceptable, it must delineate the provisions for the management of risks and certain processes that were put into place to cut down the risks of the continued viability of an organization.

Laws and Regulations

When the information security was in its infancy, the security of an organization was left only to the information security professionals. They had little infrastructure in place to defend the systems against attacks. Civil or criminal defense systems did not protect them. When they desired to seek justice from law enforcement, they had to bear with reluctance by the overworked agents who lacked even the basic understanding of how tampering with a computer can be a crime. The government's legislative branch had not included any provision for the crimes related to computers and information technology. The executive branch of the government thought that they didn't have the statutory obligation to deal effectively with these kinds of matters.

Luckily, the legal system that consists of men and women from the law enforcement department have worked hard during the past couple of decades. Different legislative branches from different countries have made attempts to tackle issues that deal with computer crimes. Many law enforcement agencies have full-time and very well-trained computer crime investigators who have

acquired some advanced-level security training. Those who don't know what to do in the wake of a cybersecurity attack or threat should check out their local laws.

Criminal Laws

Criminal laws make up a solid bedrock of the body of laws that tend to preserve peace in the organization and also maintain and sustain peace in the organization. Criminal law usually consists of high-profile cases such as robbery, assault, and arson. There are heavy penalties for those who violate criminal statutes. These penalties contain mandatory hours for community service and monetary penalties that consist of small and large fines. They also contain the imposition of the deprivation of several civil liberties.

Criminal laws, in general, serve the purpose of protecting society against computer crime. In the United States, legislative bodies establish and maintain criminal laws.

Civil Laws

Civil laws are not as serious as criminal laws in terms of penalties and sentences. However, they make a big chunk out of the law system in almost all countries of the world. It contains the bulk of the body of laws in different countries. These laws are designed as such to deal with matters related to elderly society. They also govern different matters that are usually not crimes. However, it demands a special referee to settle the dispute between two parties.

The biggest difference between criminal laws and civil laws is the way how they are generally enforced. Law enforcement authorities don't get involved in simple matters of law beyond a necessary action to restore perfect order.

Chapter Five: Security Models and Capabilities

The process of the determination on how secure the system is can be highly complicated and hard as well. It may also drain your time. The process of the determination of how secure your system should be is tough. It also is time-consuming as well.

Secure Designs

Security ought to be considered at each stage of the development of a system. Programmers should code in the way that they must integrate security to all the applications they make. Critical applications that require top-level security must be designed with special care. Especially, the applications that require the transmission of sensitive information should be properly secured. There are generally two courses to follow. The first course is to secure the application from the initial stages of development. The second course is to secure the application at a later stage of development. It is relatively easier to secure the system at the developing stage instead of securing it after it has been developed. The following sections tend to discuss some essential principles of design that must be implemented at the early engineering stage of your software.

Subjects and Objects

There is two way to access control to any kind of resource inside of a secure system. One channel is from the subject in a process. You can define a subject as a user or a process that places a request for reaching out to a resource. Access means writing to a specific resource. An object can be defined as a process that a user needs to access. You must remember that the object and subject refer to the access request therefore a resource tends to serve as object and subject in various access requests.

Open and Closed Systems

Most systems are designed by following different philosophies. The first is the philosophy of a closed system designed to work with a narrow range of systems from the same manufacturer. The standards for the closed systems are not usually made public. They are propriety and they must remain covered. However, open systems are way easier to pair up with the systems made by different manufacturers, supporting similar standards.

Closed systems are tough to pair up with different systems, however, they are way more secure. A closed system generally comprises software and hardware that don't fall in line with the industry standards. The difficulty in integrating the systems means that there will be lesser chances of attacks on the general components of a system. Either they will never work at all or they will have to be customized to be a success. A closed system is resilient to attacks as compared to an open system.

Open systems are easier to penetrate. An attacker can easily create a LAN with the help of a Microsoft Server machine. The attacker can also use a Mac system or a Linux to launch an attack that will shatter the system in a few minutes.

Integrity, Availability and Confidentiality

If you want to ensure the integrity, confidentiality and availability of the data, you ought to ensure that all the components of the system must have access to the right amount of data. There are several techniques with software designers to make sure that programs do what is needed. Take the example of a program that reads and writes from a specific spot of memory now being used by another program. The programs that need access to read and write will have to break through all levels of security which are integrity, confidentiality, and availability. If the program that has been broken into possesses sensitive data, the confidentiality of the data is not guaranteed. If the data tends to be overwritten unpredictably, integrity is not guaranteed. If the modification of data orchestrates corruption, it will not be available in the future.

Confinement

Software engineers use the process of confinement to limit what a program that they had been developing and designing can do. It means that bind the actions of a program. The process of confinement allows the program to do reading and writing to a certain memory, resources, and location. The process can be dubbed as sandboxing. The operating system tends to disallow illegal writing and reading requests inside the system. If a process seeks to kick off an action beyond a granted authority, the action is likely to be denied. Different systems must comply with the security ratings that record the violations and also respond in a highly tangible way. The process of offending is likely to be terminated. You can implement it in an operating

system by isolation and protection of memory.

Bounds

A process that runs its course on a system is generally assigned at the level of a particular authority. The level of authority instructs the operating system on the abilities of a process. If the operating system is simple, there will be two authority levels such as kernel and user. The operating systems receive instructions on setting up the bounds for a certain process. The bounds of the process span around the limits on the resources and memory address a system can access.

The operating system carries the responsibility to enforce some logical bounds and disallow access to certain processes. Many top secure systems will require the processes that are physically bound. The physical bounds need a bounded process to move in a certain spot of memory that is physically placed at a distance from the other bound processes running through the course of the system. They are not logically bound in the same place. Physically bound memory is costly because it is more secure than a logically bound memory.

The Process of Isolation

When a certain process stays confined by access bounds, the process stands isolated. It generally runs like that. Isolation ensures that a certain behavior will affect the resources and memory that are associated with it. Security personnel uses it for the protection of operating environments, apps, and OS kernel. It is considered the most vital component of a certain operating system. It aids in the prevention of an application to not access the resources and memory of other applications.

The operating system may offer intermediary services such as resource sharing and cut-paste operations. Resource sharing can be defined as the network interface, the keyboard, and the storage device access and the concepts of isolation, confinement and bounds make the designs of the programs secure and tough. They also provide you with the foundation to create and implement more secure systems.

Controls

If you want to build a foolproof secure system, you should let subjects find

their way only to authorized objects. A control makes use of access rules to restrict access to a particular subject and an object. The rules of access explain which kind of objects will be valid for a particular subject. An object may be valid for one kind of access and invalid for another. The only common control can be used to access files. You can protect your files by converting them into read-only file types for most of the users. You also can make them read-write type only for a small number of users who possess the authority for modification in the files.

Controls are of two types; one is dubbed as discretionary and the other is dubbed as mandatory. You can convert them into short forms such as DAC and MAC. In mandatory controls, static attributes of objects and subjects are used to determine the permissibility of access. Each subject in a system contains certain attributes that tend to define authority and clearance. The objects contain attributes that tend to define the classification.

Each security model defines and classifies resources in several ways. A subject namely X can get access to the object namely Y if the security system tends to find a rule that will allow one subject that has the clearance of X to get access to an object with the classification of the Y object. This kind of access is dubbed as rule-based access control or RBAC.

The discretionary control tends to differ from the mandatory controls in the way that the subject can define objects to gain access it needs. Within the desired limits, the discretionary access controls will allow a subject to define objects to gain the required access. This type of access control list generally serves in the form of an access rule that a subject can modify. The type of constraints that are imposed on the modifications relates to the identity of a subject. Based on identity, the subject might be allowed either to add or to modify certain rules that will define a subject's access to different objects.

Basics of Security Models

In the world of information technology, certain security models offer a way to formalize certain security policies. The security models can be intuitive or abstract. However, they are aimed toward the provision of a set of rules that your computer systems will follow. This is how you can ensure a smooth implementation of the basic security concepts, procedures, and processes. When combined, they formulate a security policy. These models allow you to deepen the basic understanding of the functioning and designing of a

computer system.

A certain security model offers designers a way to map out a bunch of abstract statements into a security policy that will prescribe the data structures and algorithms necessary for the building of software and hardware. A particular security model allows software designers to calculate the implementation and design of the security system.

Many methods allow you to describe the essential security attributes for a particular object. You can define a security token as an object that is linked to a particular resource. A token also describes the security attributes of the same resource. You can use the token to communicate security information about a particular object to which you need access. You can use many lists for storing security information about different objects.

Security Models

Here is a rundown of different types of security models that you can use to secure your information technology infrastructure.

- Take-Grant security model
- Biba security model
- State machine security model
- Noninterference security model
- A trusted computing security model

No system tends to be completely secure. However, you can design and build a foolproof secure model. If you have checked and believe that your infrastructure is complying with security criteria, you can say that it is exhibiting a specific level of trust. You can build a base of trust in your system, evaluate it, certify it, and accredit it. You must have a solid base on which you can build your security model.

Trusted Computing Base

This the first step toward creating a foolproof security model. A trusted computing base is defined as a special combination of software, hardware and different types of controls that work in coordination to build a trusted base for the enforcement of a security policy. A trusted computing base or

TCB is defined as a subset of the information technology system of an organization. You should keep it as small as possible so that you can ensure an analysis of the designs of a system. You can read the analysis to see if the system meets the requirements and specifications for the designs of the system. TCB is the only portion of a system that must be trusted to enforce your custom security policy to protect the information technology infrastructure in your organization.

You need not trust all the system components. However, at any point you check the system from a security point of view, the evaluation must contain the trusted components that define the TCB of your system.

In a security system, the TCB components have the responsibility to control access to a system. The TCB ought to provide certain methods to access resources from the inside and the outside of TCB itself. TCB components tend to restrict the activities of different components from the outside of TCB.

Security Perimeter

The security perimeter of a system is a kind of imaginary boundary that will separate TCB from the system. The boundary ensures no insecure interactions or communications between TCB and its remaining elements in the computer system.

Reference Monitors

When you are on the verge of implementing the system, you must develop the first parts of TCB to enforce access controls on the resources and assets of the system. The resources and assets are generally or commonly known as objects of a system. The sections of TCB that give access to resources before giving access requests is known as a reference monitor. The reference monitor is responsible for sitting in between an object and a subject. Its job is to stand and verify each request by a subject to access the object. It verifies the credentials of a subject and matches it with the access requirements before processing any requests. It is a kind of roadblock for the subject that blocks each request for entering the premises of the object. If the requirements for the access do not match, the reference monitor turns down each and every request.

Therefore, authorized activities are permitted to occur and unauthorized

activities are blocked from occurring. The reference monitor has the crucial job to authorize an action by following the instructions of a particular security model. The model can be role-based, discretionary, and mandatory.

The reference monitor needs descriptive information about the resource it tends to project. This kind of information usually includes the designation and classification. When the subject asks for access to a particular object, the reference monitor tends to consult the descriptive information

The collection of different components in TCB that work in coordination is known as the security kernel.

State Machine Model

The state machine security model is about a system that always stays secure in what state the model is in. This model revolves around the computer science definition of the finite state machine (FSM). The FSM combines the input with a particular machine state to model different complex systems, decoders, parsers, and interpreters.

Chapter Six: Security Vulnerabilities

Computer architecture is a kind of engineering discipline that is more concerned about designing different computing systems at a higher logical level. The more complex a system has, the wider are the areas that ought to be secured in the wake of threats. A higher number of threats and vulnerabilities mean that the security of your system is less trustworthy.

Memory Security Issues

Memory processes your data and stores it as well. Some data can be really sensitive such as the trade secrets of an organization. You must have a clear concept of the different types of memory. You also should know how the process behind the storage and retention of data. All the memory devices that store sensitive data must be purged before you allow them to move out of the organization. It can be in the form of emails, postage, and physical transportation as well. This is true for secondary memory such as EPROM, ROM, PROM and EEPROM, etc.

The retention of data in the memory is not limited to the types of memory. Dynamic and static RAM chips tend to store data with the help of capacitors. The biggest security threat to the RAM chip is that they are pilferable and therefore they can be easily stolen. Someone can remove a memory module from a system and simply exit the door. However, this threat is reducing because there is a clear reduction in the prices of chips. The best countermeasure for tackling this issue is that you can control the access to the computer that contains these memory chips.

Storage Devices

Each computer system has different storage devices. All these devices are used to store information that works well for other computers in which they are fitted. There are two types of memory; primary and secondary memory. The concepts of primary and secondary memories may appear to be confusing. The primary storage can be called RAM in which a computer stores only necessary information. The secondary memory includes long-term storage that you ought to use every day. The secondary storage consists of floppy disks, hard drives, compact discs, solid-state drives, and digital video disks.

Storage Media Security

There are several security issues spanning storage devices. When there is useless data on your storage devices, your staff will erase it from the device. There is a chance that you discard a hard disk drive or solid-state drive and someone gets his or her hands on them. The storage device may appear to be void of data but the data you have erased is fully recoverable. This kind of condition is called data remanence. A technically savvy person knows about the utilities used to retrieve files even after you have erased them. Also, it is completely possible to retrieve data from an HDD or SSD even after you have formatted it. If you have to remove data from a storage device, you should use a specific utility made to kill even the traces of data on your storage device. Even if the device cannot destroy the files to the point that no one cannot recover them, you should damage them to the point that they cannot be repaired. This method of damaging the files is known as sanitizing.

SSDs exhibit a problem concerning the process of sanitization. There are often certain blocks of data in SSDs that don't carry the label of 'live.' There is always an extra copy of the files stored on the SSD, which makes the traditional formatting and erasing ineffective.

Theft is one of the biggest problems when it comes to secondary storage devices. The primary loss is the economic loss but it is not one of the major factors that you should be worried about. After all, a big organization doesn't worry about these kinds of financial losses. A hacker or a social engineer, who is determined to steal data of your organization, can go to any length to steal your information. The hacker can get access to your internal security systems after he or she has the login credentials. If a person succeeds in copying your trade secrets, he can inflict significant damage to your organization. Therefore, you must use the full disk encryption methods to cut down the risk of someone entering your system from the comforts of his or her home. Encrypt your SSDs before storing any data on them.

You should define who can access the storage devices. This also falls among the highly critical issues that computer professionals face. You can protect the data on the hard disks by using the access controls on your operating system. Use encryption technologies to protect your data.

Hardware

Hardware in the world of computers is the physical objects that form a computer. Hardware, the term, includes all the solid things that a computer has from keyboards to central processing units (CPUs). The physical stuff that you can reach out to falls into the category of hardware but the contents of the hardware are not parts of the hardware. You may name them as software. Hardware is the hardest to protect as anyone can steal them. You should define who should access the server room or computer systems.

The best method to protect your IT infrastructure is to tighten the guard system in the organization. You should introduce the system of security passes in the organization so that only authorized personnel can get into the rooms that contain servers and computers that carry classified information.

The Processor

The central processing unit is named as the processor. It is the nerve center of a computer. It contains a chip that governs major operations and performs a complex symphony of calculations that make possible the execution of certain tasks. The compilers and operating systems tend to translate high-end programming languages into easy-to-understand words that a layman can understand without much difficulty.

Input and Output Devices

Input as well as output devices of a computer system are considered primitive peripherals. They don't get a lot of attention until they cease to work properly. However, these kinds of basic devices pose a great security risk to a computer system of an organization. Security managers of your organization need to be aware of the risks that the organization faces. Security managers also have to ensure that there are right security controls for mitigation of the risks. Here is a rundown of the risks involved in the devices.

The Monitors

Computer monitors appear to be innocuous at first glance. No one can imagine that a computer monitor can be risky for your organization. When a monitor is turned off, your data seems to disappear from the computer screen. You cannot recover it apparently. However, a program named TEMPEST has the power to compromise your data security.

The TEMPEST program reads electronic emanations that a monitor possesses

when it is turned on. The processing of reading these emanations from a distance is labeled as Van Eck phreaking. A hacker can execute it from a remote location. A malicious hacker can use TEMPEST to steal data that you might consider not existent. Different studies have shown that you can read monitor screens even if you are out of the office building. For example, a person sitting in his car in the parking lot can read from the monitor screens and copy the data. Protective controls that can prevent Van Eck radiation turn out to be costly if you want to implement them. They also are cumbersome for the organization to maintain after the implementation. The key is never to use CRT monitors as they emit excessive radiation unmatched by any other type of monitor. LCD monitors leak a lesser amount of radiation so they are the best option for an organization. As a security manager, the biggest risk that you can face is a risk from the process of shoulder surfing.

Office Printers

Officer printers can turn out to be highly risky for your organization. They represent a greater security risk no matter how simple it is. However, the amount of risk depends on the physical security controls that are used in your organization. For example, if you have not given considerable importance to the physical security of the organization, you may end up leaking significant information to the outsiders.

You cannot know the intentions of the people who visit your organization. Therefore, you should keep uptight physical controls on security. You can hire security guards for the organization to keep a check on who is entering the gates of your organization. A social engineer or a malicious hacker can sneak into your organization and silently steal some of the pages off the printer. You will never know what happened.

To prevent this kind of incident, you can introduce the practice of security badges in your organization so that only authorized people can have access to your organization.

The problem gets worse in the organization where printers are shared. Officer employees often forget to collect the print outs because the printers are placed at a distance from the computer system. These documents are often the target of social engineers. Modern printers also have an internal memory system to store the data until you erase it. These printers retain the last input data until it is replaced with the fresh data. Some printers have the capacity to retain data

for an indefinite period. This is where the problem starts. Malicious people can steal memory chips or entire printers because printers are often left unlocked in the offices in case they are shared. No one thinks about how vulnerable they are in terms of the breach of security of your IT infrastructure.

The worst-case scenario is that the print-outs contains passwords, login information, and trade secrets that your opponents can use to weaken your organization.

Computer Accessories

Keyboards and mice are the input devices that are considered completely immune to security threats. However, it is just a weak thought. These devices, indeed, don't have immunity against security risks. These devices are considered weak when it comes to monitoring by TEMPEST. Keyboards also are vulnerable to bugging if only it is sophisticated. A social engineer can place a small and simple device in the keyboard and cable that will intercept keystrokes. These keystrokes transmit the information typed on the keyboard to a remote receiver sitting in your parking lot. It is as lethal as the process of TEMPEST but is less expensive. So, it is highly likely that a hacker will use this technology. So, you should take great care of your keyboards and mice. The worst thing is that mice and keyboards are nowadays wireless. This means they run on Bluetooth technology and a hacker can easily intercept their signals with malicious intentions.

Internet Modems

Modems are another type of computer accessory that can be used to steal information from your organization. Almost everyone nowadays uses wireless modems which makes interception easy. If the organization uses traditional modem systems, each user in the organization has a modem on his or her computer. They will add more to your security concerns. Internet modems allow users to have uncontrolled access points in your network.

If they are improperly configured, they will be a greater security risk than any other item. In a worst-case scenario, they will create a separate egress channel that the insiders of the organization use to funnel the data out of the organization.

Vulnerabilities in Mobile Systems

Smartphones and many other mobile devices present a rising security risk to the organizations as these devices are getting more capability for interacting with the internet and corporate networks. As a security manager, if you allow mobile devices, personally owned, inside of your organization without any kind of security check, the potential for the damage is hefty. Malicious hackers may enter your organization carrying a device that has in storage a malicious code. The host carrier for the malicious code can be a smartphone, a tablet, a memory card, or an audio mp3 player. USB drives can also be used to launch an attack on the security system of the organization.

The storage devices can be used in multiple ways such as leaking important data or injecting malware into the IT system to compromise the system or to eavesdrop on what the users do on the operating systems. A single USB payload can enable a malicious hacker to hack into the Windows operating system and afterward control it from a remote location.

Mobile devices also carry highly sensitive data like emails and text messages exchanged among the employees of an organization. In case of theft or robbery, the sensitive data may be leaked. The loss of data may comprise the corporate secrets of the organization.

A device can be defined as a personal mobile device and a portable device. Hackers attack them because they find them an easy target, which means it is important that you keep sensitive information off the portable devices. You also can build a firewall and also an antivirus system to secure mobile devices. An antivirus system detects malware or a Trojan horse and protects the device from slipping into the control of malicious people.

Also, mobile devices have no immunity against eavesdropping. If a person has the perfect kind of sophisticated equipment, most mobile conversations can be heard after a hacker tap into it. You should be careful about what you are discussing on the mobile phone when you are among the general public.

Android Operating System

Android is an operating system that is powered by Linux. Google acquired the system in 2005 and the first Android devices hit the markets in 2008. The source code for the Android is open and it carries an Apache license. However, most of the devices have propriety software. Android is not just limited to tablets or smartphones. It is now being used in digital cam

technology, e-readers, TVs, and game consoles.

The use of Android phones in tablets and mobile phones allow customization of users. You can install Google Play Store apps, most of which come from unknown sources. Android is vulnerable to many security issues. These security threats include the threat of malware, malicious apps, and unprotected transmission of data. The mobile phone of an employee may be exposed to a malicious application. A hacker can root the Android devices to give a user full root access to low-level configuration settings. The process of rooting boosts the security risk of a device because a running code tends to inherit the root privileges.

iOS Operating System

iOS is an operating system built by Apple that is also available on the iPad, iPhone and Apple TV. iOS cannot be installed on non-Apple hardware. A hacker may enter the iOS system through a jailbreak procedure. This is how the hacker can install a third-party app on the operating system and access the memory and other systems of the device. This is how iOS security will be compromised.

How to Secure Mobile Devices

The security of your device is highly important. Device security is about exploring potential security features that you usually exist on a mobile phone device. Portable electronic devices (PEDs) possess fine features but they cannot benefit you until you have enabled and configured them. Therefore, you should ask all the employees of the organization to get their mobile devices' security systems enabled and configured.

Encryption

The best method to protect your mobile devices is to encrypt them. Many tablets and mobile phones have the feature of encryption. If you can encrypt the storage media, you can be sure that no one steals your precious data. Encryption is no guarantee that your data is safe if the device itself is stolen. Encryption doesn't work if the user unlocks it and leaves it in the hands of another person. Encryption doesn't work if the system has a backdoor intended to let the original user into the device because they can't unlock it. That backdoor can easily be used by a hacker to enter the system.

Mobile phones can have voice encryption. When the voice is encrypted, there is no chance that anyone can eavesdrop you. Even if someone manages to hear you talking on the phone, they cannot understand a word because the voice will never be undecipherable.

Remote Wipe

Security managers are performing remote wiping if data is stolen. A remote wipe will allow you to delete all the data on the device. You also can remove the configuration settings. However, the glitch is that the stolen device should be connected to the internet. Remote wiping is effective only if the attack is of a low level. It means that a random hacker who is not so much organized has stolen your phone. In the wake of a high-profile organized attack, there is no guarantee that your data stays secure. The device will never connect to an internet connection because the attacker will know about the process of remote wiping. Remote wiping can be simply called as the process of deletion. Encrypt the device first and then do remote wiping to ensure that the data stays secure until it is deleted. The attacker will either have to throw away the phone or connect to the internet. Whatever happens, it is good for you.

Lockouts

There is a chance that you might be locked out of your mobile phone for a while. When a staff member fails to login after multiple attempts, he will be locked out of the device for a while until the administrator gives him back access to the system. There might be a lockout feature in the device but it will only be used if you have properly configured the mobile screen lock. A simple swipe on the screen has nothing to do with the security of the system.

Screen Locks

A screen lock aims for the prevention of a person from stealing your mobile device. Most of the screen locks ought to be unlocked by swiping up a pattern by entering a few numbers on the keypad. They are not a secure option. Anyone can access the emergency dialing feature on a locked phone which is a loophole in the security of the system. A screen lock has nothing to do with the security of the system if the hacker connects to the device from a remote location through a USB cable, a Bluetooth device or a wireless system.

The GPS System

Some mobile devices contain a GPS chip to ensure the process of navigation when you are on the way. Different apps on the mobile phone operating systems may collect your location and transmits it. This can be used to track the location of the device and perpetuate a potential attack accordingly.

Access Control

Security managers should limit and monitor access to the phone or the tablet that contains sensitive information about the organization. The top method to ensure access control is to create a powerful password for your device. Most mobile devices usually are not secure that's why even with a powerful password, the device will be accessible through wireless, Bluetooth, and a USB cable. A strong password will deter any random person from looking into the device.

Removable Storage

Many mobile devices supported removable storage. Some of them support removable memory cards that many people use to expand the memory of their device. Some mobile phones need the removal of the backplate. Some mobile phones require the removal of batteries to insert or remove the storage card. Large size tablets and mobile phones support an easy-to-access card slot that is on either side of the mobile phone. Some mobile devices support external USB storage devices like external hard drives and flash drives.

App Security

There are several ways by which you can ensure the security of mobile devices. A big number of software security concerns on the notebook systems and desktop systems tend to apply to mobile devices as well.

Geotagging

Mobile devices with GPS support will enable the embedding of a geographical location in longitude and latitude coordinates. The photos also carry the time and date of the photos. This is how an attacker can view the photos from different social networking sites and know where you had taken the picture. A determined attacker can map out your daily routine and that's how he can reach your most frequented spot and steal your device or access it

from a nearby remote location.

Embedded System Security and Mitigation Measures

Security Measures

The security measures in regard to the static and embedded systems are designed with the attention to cutting down the costs and the extraneous features. This leads to a lack of security or patches. As a particular embedded system stays in control of a particular mechanism in this physical world, a small security breach can harm the property and the people. Embedded systems and static environments need sophisticated security management. Here are a few measures that you can take to secure your organizational systems.

The segmentation of networks involves controlling the traffic that is distributed among different networked devices. Transactions can only happen between devices inside the segmented network.

There are several security layers in which devices that have certain levels of sensitivity and classification stand grouped together or in a one-directional form. The isolation can be unidirectional or it can be absolute. A lower level may not initiate communication with the higher-level system. However, a higher-level system may initiate communication toward a lower level. Isolation can be logical or physical. The logical form of isolation requires classification based on packets and labels that ought to be respected as well as enforced by the operating systems, network management, and applications.

A firewall inside an application is a certain device, a virtual service, a system filter and a server add-on that will define a bundle of communication rules for all users and services. It is an app-specific firewall that is used for the prevention of payload attacks and app-specific protocol.

Physical Security

Another domain of security is physical security. The main objective of physical security is the protection of an organization against physical security threats. Here is the rundown of the physical threats that an organization faces.

- The threat of smoke and fire.
- The threat of rising or falling water from floods, leaks, etc.

- The threat of wind storms, rainstorms, hurricanes, tornadoes, and lightning storms.
- The threat of landslides, earthquakes and volcanoes.
- The threat of explosion or any other kind of destruction.
- The threat of the collapse of building due any natural or human cause.
- The threat of the spread of toxic materials.
- The threat of the failure of any equipment and electricity to power it, including back-up generators.
- The threat of robbery and theft.
- The threat of the loss of power during work, extra heating, extra cooling, water and air.
- The threat of the loss of personnel like illness, transportation issues, strikes and access.
- The threat of snow and sleet accumulation in or around the premises.

Secure Principles and Facility Design

A special security plan will outline particular security needs for your organization. It will also emphasize mechanisms and methods to provide security. This kind of plan is generally developed by a process known as the critical path analysis. The critical path analysis is a special kind of systematic effort to identify the relationships between processes, mission-critical applications, and operations.

When you conduct a critical path analysis, a full picture of interactions and interdependencies necessary to support your organization is conjured. Once the analysis has been completed, the results of the analysis give you the list of items that you must secure. The first step in the designing of an IT infrastructure is the provision of security to fulfill the basic requirements of an organization. The basic requirements include heating, electricity, environmental controls and humidity.

When you examine the critical parts, you must evaluate the convergence of

technology. Technology convergence can be defined as a tendency of an organization to offer several utilities, technologies, and solutions. This ends up on different systems performing redundant tasks with one system adopting the abilities of another system. In some cases this may result in enhanced efficiency and savings of expenditure.

Security staff must participate in the facility and site design considerations. Otherwise, there are many aspects related to physical security that are essential to be considered in all their entirety. If the security staff is involved in the physical design of the facility, you will be able to get the long-term security goals fulfilled. Your security goals will be supported by the personnel, the policies, and the electric equipment, and in addition by your building itself.

Selection of Site

The first thing to ensure physical security in your organization is the selection of the site. This process must be based on the particular needs of your organization. In this regard, the location, the size and the cost of the building are very important. When choosing a site for your organization to build your facility, you must select a certain pre-existing structure. You must make sure that you examine each aspect of the location.

The security of your assets largely depends on the security of your site. You have to consider a number of situational factors when you are reviewing the physical security of the organization. The construction and site location plays an important role in the process of site selection. The factors that you must take into consideration are that the site should not be located in an area that is prone to looting, riots, vandalism and break-ins. The area should not have a low crime rate. It also should not be located along environment fault-lines and the regions in which hurricanes and tornadoes happen.

The proximity of your building with other buildings is a crucial consideration. What kind of attention will your building draw? How does the location of the building affect the operations of your organization? If a nearby business is attracting a lot of customers and generating lots of noise in the process, causing a lot of vibrations or handling some toxic materials, they will harm your business, building, customers and employees. Your proximity to a bunch of emergency-response personnel is one situation that can adversely affect you. Some companies can afford to build or buy the

campuses, thus keeping the neighbors out of the play. Their budget can allow them to put in place tighter access control as well as monitoring. Every company cannot do the same and they must adapt to the resources that are available to them and are also affordable as well.

Visibility of the Building

The visibility of the building of your organization is very important. You should take into account the surrounding terrain. You must take into account if it is easy to approach your facility on a vehicle or foot unseen by a single person. The makeup of your surrounding area is very important. For example, work out how many trees are in the area. You should survey the length and the width of the bushes behind where a person can hide while standing in an upright position. Is the building of your organization close to a residential area or an industrial area? Based on this data, you should calculate the number and distance of emergency service departments such as health, fire and police. If the office building is in a place where there are many blind spots and people can escape security cameras. Similarly, there should not be any high bushes that give a prying person space to cloak himself.

Natural Disasters

Another concern is the potential impact that different types of natural disasters may exert on the area. You must consider if the area you live in is prone to fires, tornadoes, earthquakes, ice, rainfall, snow and heat. You must prepare yourself according to which natural disaster is common in your area.

The Design

The design of the facility is another important thing that you must consider during the construction phase. The level of your building's security is another important thing that you ought to consider. There should be a well-thought plan to secure your organization. You should properly plan your security and the design of your building before starting the construction phase.

Other important issues that you must consider are fire rating for the design, placement, combustibility, and control of items like ceilings, water, doors, gas, power and HVAC. Emergency access, alarm sets, forced intrusions, resistance to the entry, and conductivity are some important factors that you must consider. Each element in the facility ought to be evaluated to examine if the IT infrastructure will be well protected and the personnel well-secured.

To do an in-depth analysis, you need to look if the flow of air supports or destroys the building and keeps the water from inside the facility.

The most important issues to consider are construction materials, combustibility, doors, ceilings, water, gas, HVAC, power, and load rating. Each element inside a facility should be evaluated for how you can use it to protect the infrastructure in your organization.

Physical Security Model

The security controls that are implemented to implement physical security ought to be divided into three major groups such as technical, administrative and physical. These are the same categories that are used to describe the access controls. You must focus on the physical security of the organization. Administrative controls to ensure physical security span around the construction of the facility, the selection of the site, the management of your site, the level of awareness training, the different kinds of procedures and emergency responses, and personnel controls. The technical physical security controls encompass alarms, access controls, monitoring, heating, air conditioning and ventilation. It also takes into account the fire detection process and power supplies.

A lot of businesses have invisible and visible physical security controls. You can see these controls at the post office and in different other environments around you. They are pervasive and differ as people design them according to their requirements. You might have seen gated communities around you.

When you are designing the physical security protocols for a particular corporate environment, there are some key factors that you must take into account before moving forward. You need to design physical security in the manner in which controls ought to be used. The order is as under:

- The first step is to ensure deterrence.
- The second step is to ensure denial.
- The third step is to ensure detection.
- The fourth step is to ensure delay.

Security controls for an organization ought to be deployed so that the initial attempts to access the physical assets must be deterred. This is the primary

layer of physical security, which will discourage prying people. If deterrence fails to keep the attackers away from the organization, the next step is denial. It means that you deny people access to your systems by installing heavy locks and impenetrable boundaries in the facility. You can use locked vault doors for the purpose. If denial fails, your system must be able to detect any level of intrusion. You can use motion sensors to delay the intrusion by a prying person.

When you are designing the security system, you must take care of the order of things. For example, you cannot reorder the protocol by placing denial at the start.

Wiring Closets

Wiring closets are small closets where you have to pack up the telecommunications cables. A wiring closet can also be used for other purposes. It is one of the most important parts of the infrastructure of an organization. A modern wiring closet is where the cables are connected to other equipment such as switches, routers, and panels. If the organization is a large one with a large building, it requires more than one wiring closets so that the system may stay inside the cable run limitations. For the common copper-based cabling, the average length is one hundred meters. In a noisy environment, the run length ought to be reduced. These closets serve as a viable location to connect different floors. Wiring closets are known to manage and house wiring for different types of elements like circuit breaker panels, security cameras, and alarm systems.

Wiring closet security is really important. Most security for a wiring closet tends to focus on the prevention of unauthorized physical access. If a prying person gains access to an area where he is not supposed to stay, he may steal the cut cables, equipment, and other instruments. He can even have the power to plant a bugging device to hear your communications. To ensure foolproof security for wiring closets, you can take the following measures.

- You should never use a wiring closet as a place for storage.
- You should install adequate locks in the facility.
- You should keep your area neat and clean.
- You should never store flammable items inside the facility.

- You should set up proper video surveillance to ensure monitoring activity within the wiring closet.
- You must install open door sensors to log in the entries in the facilities.
- You must not give away the keys to a random person.
- There is a need for performing physical inspections of the security of your wiring closets.

The Server Rooms

Wiring closets, server rooms, and server vaults are enclosed and protected rooms keep critical servers safe. Centralized server rooms must not be compatible with humans. The more a room is compatible with humans, the higher the level of protection it has to offer.

You can accomplish human incompatibility by including PyroGen, low temperatures, and by stacking the equipment together so that there is little space to maneuver. You should design server rooms in a way that they support the operations of an IT infrastructure and also block any kind of unauthorized intervention.

Server rooms need to be located at the center of the building to make penetration impossible. The ground floor, no matter how tempting it appears to be for the placement of the server rooms, should be opted out of the equation. The top floors also are not the best choice. The basement also is not a good idea. You should locate server rooms at a place that is safe from water, sewage, and gas lines to minimize the threat of leakage and flooding. Both can trigger significant damage and may also result in the downtime of the organization. The walls of the server room should be tested for one-hour fire rating.

The best method to ensure maxim security is to keep the server rooms away from access. The most secure system is the one that doesn't have a valid internet connection and that is placed in a sealed room that has no windows or doors. However, that's a piece of fiction. In reality, we cannot develop or keep such a place that is too much isolated.

Although such a system is practically impossible to set up, you can design a server room that is securer than other systems. For example, you can set up

the server room on the first floor in a room with no windows, and only one enter and exit point. The place for the server room should have limited access. There should be sufficient hurdles for unauthorized entry. Install cameras and take care that no blind spot is left out.

Media Storage Rooms

You should also ensure the proper security of the media storage rooms. You should design them well to store the blank media, installation media, and the reusable media. The storage media that should be properly stored can be hard disks, tapes, flash drives and CR-Rs. The media that can be often reused like thumb drives or portable hard drives should be protected against data theft. You can secure a blank media device to prevent a person from injecting malicious code into the media.

You must protect storage media against malware plantation and theft. Here is a rundown of the elements that can help you keep your storage media safe.

- You should make sure that you are keeping the storage media locked inside a safe.
- There should be a custodian who is well-versed in physical security threats and who can manage access to the vault that contains the devices.
- You should put in place a check-in and check-out process for tracking who has entered the space. Whenever a mishap happens, you will be able to track down the person responsible for the theft. This will also act as a deterrence for any future event of the same kind.

You also can print out different security labels and paste them on the storage media to ensure that it doesn't go into the wrong hands. The label will help you keep the storage device safe in the hands of personnel who have the permission or authority to use or see the contents of the device.

Chapter Seven: Secure Communications

The data in a static state on your hard disk device or solid-state drive is quite simple to secure. As long as you have maintained the physical security and you have also made sure that logical controls are in place, the stored data will remain confidential. It will retain its integrity and authorized personnel will be able to use it.

However, once the data gets into the use of an application or it is communicated over a network, you will find it hard to secure. Communication security will cover a diversity of issues that are concerned with the flow of electronic information from one spot to another. The transportation may flow between different systems from one end of the planet to the other end of the planet. The flow of data can be inside the facility from one system to another system. Once the data gets into the loop of transportation, it will become weak and highly likely to fall prey to threats to its integrity, confidentiality and availability. Most of the threats ought to be reduced by adopting appropriate countermeasures.

Communications security is generally designed to prevent, detect once an attack has been launched against the data, and also correct the transportation of data to reduce the chance of errors that will comprise the security of data. It offers protection of integrity and confidentiality. This is usually done to sustain network security so that data can be shared in a secure environment.

Voice Communications

Voice communications are vulnerable to attacks. This typical vulnerability is linked to the security of IT security. As the voice communications move on to networks with the help of digital devices, secure voice communications become highly important. Voice communications should be properly authenticated and integrity must be maintained. You can use an encryption device to secure the communications while the data is in transit.

Private Branch Exchange (PBX) and PSTN/POTS types of communications are usually vulnerable to eavesdropping attacks, interceptions, and other types of exploitations. Physical security is often required for the maintenance of control over the voice communications that are made inside of the system.

Voice Over Internet Protocol (VoIP)

This technology can envelop audio inside IP packets to support certain telephone calls made over TCP/IP network connections. The technology has gained top popularity because it is highly cheap for individuals and companies alike. It is highly important to keep the security of the IT infrastructure in consideration when you are opting for the installation and usage of VoIP systems to make sure that it offers top privacy according to your expectations.

However, a few VoIP systems are in a simple form that can be intercepted easily. It is also easier to eavesdrop them. There also are some highly encrypted systems. They deter any attempt of interference and wiretapping.

When you have to install a VoIP system in the facility, you should consider the problems that accompany it. Hackers can stage different kinds of attacks such as the following:

- They can use a fake caller ID by using different VoIP tools so that hackers can launch phishing attacks.
- Hackers may also launch man in the middle (MitM) attacks by launching spoofing call managers.
- The VoIP is also a network therefore it carries the same vulnerabilities that a network has such as the threat of eavesdropping, interceptions, and interference.

Social Engineering

Social engineering is a unique kind of attack that is related more to people than the networks. Malicious hackers plan to exploit voice communications through this technique. In a social engineering attack, an unauthorized person will try to win the trust of a person privy to the secret of an organization. Social engineers are experts at convincing the employees of an organization they have relations with the upper management or the technical wing or the people at the reception. They try every bit to convince the employees. Once they succeed in their effort, the victim is encouraged to introduce a change in their user accounts by resetting the password.

Another technique is to convince the employee to open a malicious email or install an application. All these activities are linked to directing the effort toward installing a back door channel that the social engineer, the malicious

hacker, will use to get into the system and wreak havoc at will.

Instead of the networks in these types of attacks, the people become the Achilles heel that weakens the organization. Even a little information is sufficient for the social engineer to maneuver an entry into the network system of an organization.

Social engineering is considered a fascinating subject. It is the way to shatter a technically secure environment. When a malicious hacker cannot hack the network, he uses this method to collect necessary information first to launch an attack on the network. A social engineer can use a disgruntled employee of our organization whom you have fired from the job. A social engineer can make friendship with an employee or offer him money in return for confidential information. Social engineering cannot be defended against until you educate your employees about how a malicious hacker can approach them and extract the information they need.

The interaction between a hacker and the employee of your organization can be through email, IM or it can be a face-to-face meeting. You can take the following measures to counter this kind of threat.

- You should educate your employees on staying cautious about odd communications or totally unexpected communications.
- You should educate your employees on getting the proof of identity of any person who tries to get close to them and also talk about the organization they work in. The employees may ask for their license number, employee ID, social security number and any other documentary proof. You can verify any of the above-mentioned information from the concerned office. If the caller claims to be a project manager, you can first confirm his identity from the respective department and then proceed with the delivery of information.
- You should educate your employees on the importance of demanding the callback authorizations.
- You should educate your employees on the importance of the secrecy of classified information like passwords, usernames, dial-in numbers, and names of the manager.

- You should educate your employees on dealing with a person who requests a piece of information over the telephone. Revealing personal information should be against the policy of a company and strict action should be taken against the personnel who reveal this type of information. The employees should be trained on asking the right type of questions from the caller and verifying caller ID. If an employee finds out something fishy about the caller, he or she should immediately report the incident to the security manager of the organization.
- There should be a blanket ban on giving out information about passwords on the phone.
- The biggest threat that an organization faces in terms of social engineering is the disposal of information. When you dispose of the official documents, you should always use a proper destruction process to get rid of the documents you don't need. For example, you may need a cutter to cut papers into pieces and an incinerator to burn down the pieces as well so that the chances are bleak that the waste papers don't get into the hands of malicious hackers. The situation can be highly dangerous if a paper that contains the login credentials of your organization goes into the trash can from where a social engineer collects them.

Multimedia Collaboration

Multimedia collaboration is defined as the use of different multimedia-supporting communication apps to collaborate among between from a remote location. People who have been working on a project can collaborate together. The collaboration facilitates the staff to work simultaneously across multiple time frames. Remote collaboration may be done with the help of an email system, videoconferences, and VoIP. You may also have to use Google Docs editing, versioning controls, and different other tools. It is more often an advanced form of remote meetings to improve the speed and efficiency of work.

Remote collaboration technologies are often used for hardware, any type of products, and software that facilitate you to conduct meetings from remote locations. These solutions and technologies are known as virtual meetings, shared whiteboard services, digital collaboration, and application

collaboration. A service that enables a bunch of people to exchange data, to communicate with other people, and to share documents and materials fall into the category of remote collaboration technology.

Regardless of how multimedia collaboration should be implemented, the security implications of those should be implemented. You should take into account and keep in place robust techniques for the authentication of the team members. You also should encrypt the communication among team members.

Email Security

The email system is the most widely used Internet service. The email infrastructure includes email servers that are backed by the Simple Mail Transfer Protocol (SMTP) for accepting messages from the clients. The messages are then transported among different staff members of the organization. Once they are transported, they are deposited into the inboxes. The email infrastructure also includes emails of clients. Several email systems that are compatible with the internet tend to rely on X.400 standards for handling messages and addressing them as well.

Unix systems use a Sendmail system that is also written as SMTP in a short form. When you deploy the SMTP system, you should properly configure the authentication for the inbound and outbound mails. SMTP is designed to act as a relay system for mails. It attempts to relay emails from the sender to the recipient. You should take care that the SMTP server is not an open relay system. Open relays are highly vulnerable to spam attacks because they give spammers the freedom to send lots of emails by piggybacking on the insecure email infrastructure.

Objectives of Email Security

The basic mechanism is an email infrastructure that offers efficient transportation of the messages but it lacks the controls to ensure the much-needed integrity, confidentiality, and availability. Email is insecure. However, you can make it secure in by taking several steps. You can get the following benefits when you secure your email infrastructure.

- You can provide for non-repudiation.
- You can limit access to the messages that are meant for the intended recipients. In short, you can ensure the confidentiality

and privacy of messages.

- You can secure the message from losing their integrity.
- You can verify and authenticate different sources of messages.
- You can also verify the message delivery.
- You can classify the sensitive content that is attached to the messages.

You should draft acceptable and practical policies about what activities should be followed and what should be refrained from the email system of an organization. Access control over the email system ought to be maintained so that the users possess access to the specific inbox and the email archive database.

As a security manager, you should create, maintain, and sustain the processes and mechanisms for the email system of your organization. The end-users of the email system don't need to know the processes behind the email infrastructure. However, they should know whether you have made the email a private communication or not.

The Issues

There are many email security issues. The first step in the deployment of email security is recognizing the vulnerabilities that are particular to an email system. There is no space for encryptions. All the messages that are transmitted often reach the email server in the form of plain text. This clears the road for interception and eavesdropping. However, the absence of native encryption is not as much important as other security issues are regarding email security.

The biggest security issue that the email infrastructure face is recognizing the vulnerabilities that are specific to email. You should be more worried about the worms, Trojans, and viruses. You also should be concerned about destructive macros and several malicious codes. Emails offer a little in the wake of the verification of the source.

Email can also be used as the form of a mechanism of attack. When there are sufficient messages that ought to be directed to the inbox of a single user, you may suffer from a denial of service attack. The attack can be dubbed as mail-bombing. The most common technique to triggering this kind of attack is to

inundate a person's inbox with many emails. The DoS may occur due to low storage capacity and the processing of capacity utilization. The result of this kind of attack is that even legitimate messages cannot be delivered.

As is the case with flooding of emails and malicious code, the unwanted emails fall into the category of attacks on the system. Inappropriate emails, unwanted emails, and irrelevant emails are in common terminology called spamming. Spamming is a kind of nuisance; however, it wastes local resources. Spamming is hard to stop because the source is a spoof therefore you cannot detect and stop them.

Security Boundaries

A security boundary divides two areas or environments that possess different requirements for security. A certain security boundary resides between a low-security and a high-security area in the virtual world. You must recognize the security boundaries on your own network and also in the physical world. Once you have identified a particular boundary, there is a need to deploy security mechanisms for controlling and channeling the flow of information that is spread over multiple boundaries.

There are divisions between different security areas that may transform into multiple forms. There may be different classifications for objects. Each classification will define what kind of functions ought to be performed by one subject to another.

There are security boundaries between the logical environment and the physical environment. To ensure logical security, you ought to provide the security mechanisms that must be different for those used to offer physical security. Security boundaries between a protected as well as an unprotected area must always be defined clearly.

Mitigation Measures

Communication systems remain highly vulnerable to attacks because there always is a threat to the IT infrastructure. You must understand the nature of threats and also the possible countermeasures to secure an environment. Any condition or activity that harms the resources or data or personnel should be addressed. You must mitigate it as well if it is possible.

The most common threats that require immediate and consistent mitigation

measures are denial of service attacks, impersonation, and eavesdropping.

Denial of Service Attacks

These are resource consumption attacks aimed at the prevention of legitimate activities waged on a victimized system. A DoS attack makes the target not responding to a legitimate user or legitimate traffic. The two types of denial of service attacks are as under:

- The attacks that exploit a certain vulnerability in a software or a hardware fall into this category. The exploitation of an error, a weakness, or a standard feature of software tends to hang the system to freeze. The final result will be that the victim computer will not process any legitimate traffic or data.
- The attacks that tend to flood the communication of the victim.

DoS is not a single attack but it is rather a class of attacks. Some of the DoS attacks exploit the flaws in the operating system while others focus on applications installed on the system. They also focus on the protocols and the services of the system. Here is a rundown of the countermeasures to prevent and deter this kind of attack.

- You can build firewalls, intrusion detection systems and routers that will detect DoS traffic, block the system, and eventually drive out the packets bombarded on the destination address.
- The key to effective prevention is to stay in good relations with your service provider and request filtering services in the wake of a DoS attack.
- You also can opt for disabling the echo replies on the external systems.
- The best method is to disable the broadcast features on security border systems.
- You can opt for blocking spoofed data packets from infiltrating or exiting the network.
- You can keep the systems properly patched by downloading and installing updates from the vendors of your antivirus software

system.

Eavesdropping

Eavesdropping is the secretive listening of online communications and the interception of the data that is being transported. Attackers may seek to duplicate the data and use it for nefarious purposes. The duplication can be done by data recording and by using the extraction program that will attempt extraction of original content from a traffic stream. Eavesdropping allows an attacker to steal passwords, usernames, and many other forms of data.

Eavesdropping demands physical access to IT infrastructure to connect a particular physical recording device to the open port to install a particular software recording tool.

You can fight off eavesdropping by ensuring physical security so that no unauthorized personnel accesses the IT infrastructure. As for the protection of off-network communications or the protection against internal attackers, one-time authentication methods on the communication traffic will cut down the timeliness and the effectiveness of the process of eavesdropping.

The major security measure to prevent eavesdropping is to ensure secure communications in the first place. When the data is processing, it is vulnerable to interceptions. Therefore you should keep your line of communications out of bounds of an organization. Reliable means the security of data while it is transmitting out of the internal infrastructure. Hackers may use sniffers to steal data therefore you need to stay awake and vigilant when you send the data in transit.

Chapter Eight: Incident Response

One of the key ingredients of a security program is that you should prevent security incidents. However, incidents do occur therefore you should be able to respond to security incidents effectively. When they do happen, you must have a security response plan ready to launch to slow down the threat and neutralize it eventually.

Defining Incidents

Before you dig further into the response to the incidents, you must understand what an incident is. Although they appear to be simple yet you will find that there exist different kinds of definitions based on context. An incident in an organization produces a negative impact. An incident adversely impacts the integrity, confidentiality, and availability in an organization. It affects the assets of an organization and is typically unplanned. It will reduce the quality of the IT services of your organization. The definitions encompass different events such as the attack on your computer systems through hacking, the direct attacks on your organization's assets, different kinds of natural occurrences such as earthquakes, tornadoes, hurricanes, and heavy rain spells. An incident can be the one that will cut the cables of your organization.

Organizations define an incident when they design their security policy. They also define an incident in their incident response policies. The definition ought to be one or two sentences long. They may also include examples of common events. The organization generally classifies a security incident in the following words.

- An incident in an organization can be an attempted intrusion in the network system of your organization.
- An incident in an organization can be a denial of service attack on your network system.
- An incident in an organization can be detecting a Trojan, malware, or any other kind of malicious software.
- An incident in an organization can be an event in which an unauthorized gets access to your organization through online interception or a malicious act of social engineering.

- An incident in an organization can be a violation of a set of security policies.

Response Making

The effective response to an incident is generally handled in several phases. You must realize that the incident is a kind of ongoing activity.

- The first step for the response making process is the detection of the threat.
- The second step for the response making process is designing the response to the incident.
- The third step for the response making process is the mitigation measures.
- The fourth step for the response making process is reporting the incident to the senior management or other concerned personnel.
- The fifth step for the response making process is recovery from the damage that has been inflicted by the incident. It can be a loss of hard disk drives, solid-state drives, or important printouts. It can also be the theft of modems and entire computer systems.
- The sixth step for the response making process is the remediation of what can be done to compensate for the loss of the organization.
- The seventh step for the response making process is to learn what lessons you can learn from the incident. For example, you may learn that you will have to secure the hard disk drives by locking them in a vault.

Incident response making has no space for a counterattack against the hacker. Launching attacks on the person or organization that has destroyed your IT infrastructure is illegal and immoral. Also, it is counterproductive because it will trigger a chain reaction in which the two organizations will destroy each other in an attack race. If a security professional can recognize the attack on the organization and identify the attacker, the result will be an escalation of attacks by the same attacker so that the victim organization's systems may not launch a counterattack. Moreover, it is useless to find the attacker because

in most cases the attacker use spoofing methods to hide their identity. Counterattacks may be launched against an innocent person or organization because of mistaken identity.

Detection

IT environments include many methods to detect potential incidents in the organization. You can use several methods to detect potential incidents. Here is a rundown of the incidents you can use for detection purposes.

- You can use anti-virus or anti-malware systems to detect any kind of intrusion or injection in the IT infrastructure. Anti-malware systems display a pop-up window to notify when it will detect the malware.
- There are some automated tools that will regularly scan the audit logs to look for any kind of predefined events like the use of special privileges. When the tools detect any kind of special event, it will send a particular alert to the administrators of the system.
- The end users also detect many irregular activities and administrators to seek help.

Response

A lot of IT professionals can be classified as the first responders for the incidents. When you have verified and detected a particular incident, your next step should be to respond to the incident. The response to the incident may vary while depending on how severe an incident is. A lot of organizations possess an incident response team that security managers may designate. The team can be dubbed as a computer incident response team. The organization tends to activate the team in the wake of a security incident. An incident response plan has the job to document who has the responsibility to activate this team and it will also define the conditions as well.

You should train the team members on responding to the incident and the response plan of the organization. The team members will assist with the investigation of the incident and they will also make assessments of the damage and the collection of evidence for the attack. They will report different incidents and procedures for the recovery and take part in remediation and the lessons they learn on different stages.

The faster a particular organization responds to a certain incident, the better the chance is that they will limit the damage to the organization. The attacker might attempt to access the database of an organization. If your response is fast, you will block the attacker from achieving any kind of meaningful data.

After you have concluded the investigation, management might decide for the prosecution of the individuals who are responsible for the attack. You must protect the data as a kind of evidence during an investigation.

Mitigation

Mitigation attempts to limit the incident. A primary goal of the incident response is the limiting of the effect of an incident. If the infected computer sends data to the network interface card, a technician tends to disable or disconnect the cable from the NIC. Sometimes the process of containment includes the disconnection of a network from different other networks for the containment of a problem inside of a single network. When you have a problem that is isolated, the security personnel will be able to address it without letting it pass to the other networks.

Reporting

Reporting is about reporting the incident inside of the organization and the individuals out of the organization. There is hardly any need for the reporting of minute malware infections to the managers of the organization. Reporting should not be sent to the top-level management about the breaches in security.

WannaCry ransomware attack of 2017 affected over 230,000 computers in over 150 countries in a single day. The attack also infected computer systems in the United Kingdom. As the IT personnel learned about the impact of the attack, they started reporting it to the supervisors. The reporting also reached top-level management. That complicated the situation as the organizations had a legal requirement to report certain incidents out of the organization. The laws differed from state to state and from organization to organization.

Recovery

After the investigators gather evidence from the system, the next step is the recovery of the system. The process of recovery is simple for minor incidents. All you need to do is rebooting the computer system. However, if

your organization suffers from a major incident, it is likely to require a complete rebuilding of the system. You will have to restore the data from the backup systems.

You will also have to rebuild a compromised system to drive out any back channels and loopholes. When you have done that, you must ensure that the system is configured well. It also ought to be as secure as it had been before the incident. If the organization possesses effective configuration process, you will easily rebuild your computer systems.

Remediation

The remediation stage needs the personnel to take a look at a particular incident and try to identify what permitted it to happen. You can use those methods to block it from happening in the future. The best way to do remediation is to do a root cause analysis of the computer system.

A root cause analysis will examine an incident to determine why it has happened. If the attackers have accessed your organization's database through your website, the personnel will look at different elements of your system to assess the backchannel behind the intrusion and theft. The root cause analysis of the attack will determine what vulnerability lies in your system. You can mitigate it accordingly.

Lessons

The last step in the process is learning the lessons from the attack. The personnel will examine this incident and respond accordingly to see if you can learn any lessons from the attack and the remedial measures. You will also have to involve the incident response team in the process.

During the examination of your response to an incident, the security personnel will look out for different areas that can be improved. For example, if the incident took a lengthy period to be contained, the investigation will try to know why it happened.

The output of the stage ought to be fed to the detection stage of the management of the incident.

Preventive Measures

The top preventive measure is to keep your computer systems and

applications up-to-date. You can ask the vendors to remove security flaws and to eliminate the bugs. You also should remove or disable the services that you don't need and the protocols that you don't use. You also can use the method of intrusion detection so that you may know before an intruder will enter the system. You should use up-to-date anti-malware systems. You also should use firewalls to protect the IT infrastructure.

Security professionals ought to stay aware of common attack methods so that they may take a few proactive steps of prevention.

Penetration testing is a specific preventive measure that you can use in your organization to defy potential attacks. A pentest or a penetration test is just like a real attack, orchestrated to spot the point of weakness in your organization. By organizing a pentest, you can identify the techniques that attackers can deploy to break through the security layers and wreak havoc in the infrastructure. A pentest can be a DoS attack, a port scan or a social engineering attack.

Penetration testing is usually intrusive and it can largely affect the system's availability therefore you should secure written approval from different department heads of your organization. Regular pentests help to evaluate security measures. They will highlight if there is a potential weakness in the system that a malicious person may exploit. You can take the pentest a step further by examining how much a loophole can be exploited.

You can use a vulnerability scanner to test a system whether it is vulnerable to SQL injection or not. Penetration testing also focuses on the education of the employees regarding the concept of social engineering. The method assesses how a potential attacker can use social engineering tactics to intrude into a system and retrieve sensitive information from the employees.

Your pentest will tell you the following:

- You will know how much tolerance your system has in the wake of an attack.
- You will be able to identify how much ability your employees have to spot and counter a potential attack in real-time.
- The pentest will tell you how much shortage you have in terms of security controls. You will also get to know how you can

implement the missing controls to cut down the security risks.

However, you should take into account the potential dangers. The biggest danger with pentests is that they may trigger system outages. They may also weaken the system for the time being and a malicious person may benefit from this period. Either you may assign the responsibility of pentesting to an internal security manager or you can outsource it to an outsider to have an unbiased opinion. The best exercise is to hire a person from the outside.

Conclusion

Now that you have made it to the end of the book, the next step is to practice what you have learned. Information security is gaining high importance because the credibility of an organization depends on it. As a security manager, you should be well-versed about the key aspects of managing the security of your organization.

As the world turns digital, more organizations will suffer from one or the other kind of data breach. In this hyper-connected world, these breaches will turn out to be a great danger for different types of organizations and security managers. The greatest threat is the loss of money. There are several financial issues such as the immediate cost of recovery from the data breach and compensating your consumers. In contrast, other costs include a drop in the market share value and a boost in security costs.

Financial costs are just one aspect of a data breach. In today's world where reputation sells, the spread of the news of a data breach in an organization defies prospects. The damage that a data breach can inflict on an organization can devastate it. The damage can be humongous in magnitude if the news spreads out that the data breach was avoidable. Prospects and customers will lose trust in the organization.

Apart from the loss of prospects and customers while you cope with the data breach, your organizational operations will be disrupted. When you announce that your organization suffered a data breach, you have to cease the operations of your organization due to investigations. The operations may disrupt due to the loss of data. Moreover, closure of operations is also the best choice when you find out that someone is lurking inside your IT infrastructure. Closure of operations saves you from losing more data. This also gives you ample time to focus on locating the source of the intrusion. However, shutting operations also has its side effects. The longer your business stays closed, the more customers you will lose, which will give a giant jolt to your revenue collection.

Information breaches also land you in legal troubles as well. You may have to deal with class-action suits. For instance, Home Depot had to pay out large settlements and lawsuits after it suffered a data breach that exposed the credit card information of their customers. In addition to paying settlements, you will have to pay legal fees as well. In certain circumstances, authorities may

restrict certain operations of your organization.

Once the information slips out of the organization, you cannot compensate for the loss it will inflict on you're the reputation of your organization. Different data breaches such as the like of Sony have shown it in the past. Therefore, the best method is to consider the loopholes and all the possible options of intrusion and make a conscious effort to block all entrances into the system.

You can keep this book as a handbook to learn about the security principles, threats and countermeasures to guide well the management of your organization.

References

<https://www.pdfdrive.com/isc%C2%B2-ciissp-certified-information-systems-security-professional-official-study-guide-d60759482.html>

<https://www.investopedia.com/terms/b/business-continuity-planning.asp>

<https://www.dummies.com/programming/certification/apply-security-governance-principles-ciissp-exam/>

<https://www.cisco.com/c/en/us/products/security/incident-response-plan.html>